

Auctor.GRC.

From assertion to authority.

V3.0.10 · DEMO GUIDE · 13 STEPS + RUBRIC BEAT · 30-MIN HEADLINE
RUN · 60-MIN DEEP DIVE

Auctor.GRC.

A workflow-by-workflow guide to the Auctor.GRC demo. **Thirteen steps, anchored by two headlines: the multi-tenant DoD hierarchy (Misbah's CFPB-pattern feedback) and the continuous-drift triage autonomy spine.** 30 min for a tight walkthrough · 60 min if the audience asks deep questions (recommended for the Tue 5 May session). Each step shows what gets clicked, what loads on screen, what it proves, and why it matters to a federal cyber team. Self-contained — anyone receiving this PDF can follow along.

This is a near-production POC

Everything an evaluator would expect to see is **real**:

- + **Real frameworks:** NIST 800-53 Rev 5 · NIST 800-171 · NIST SP 800-37 (Risk Management Framework) · NIST SP 800-137 (Continuous Monitoring) · NIST SP 800-18 (System Security Plan) · NIST SP 800-53A (Assessment Procedures) · NIST FIPS 199 (Categorization) · CMMC 2.0 · DoD Zero Trust Strategy 2.0 · FedRAMP 20x Moderate
- + **Real systems-of-record referenced:** eMASS · SPRS · Advana · DoD Cloud Computing SRG (IL2/IL4/IL5/IL6)
- + **Real audit conventions:** DIBCAC virtual + on-site · C3PAO Level-2 certification · self-assessment · internal dry-runs
- + **Real legislation:** NDAA Section 1512 (AI cybersecurity policy mandate) · NDAA Section 1513 (enforcement)
- + **Real federal data sources, plumbed live** (default ON since v3.0.9 · `?live=off` to opt out): NIST OSCAL controls catalog (324 NIST 800-53 Rev 5 controls) · NVD CVE feed (200 most recent critical/high) · Congress.gov NDAA full-text (Sections 1512 + 1513, via server-side proxy) · Federal Register notices (30 most recent cyber-related) · FedRAMP Marketplace (309 currently-authorized cloud service offerings). Source attribution renders inline as `<LiveAttribution>` chips.
- + **Real continuous-drift autonomy spine:** every triage event in the queue is generated by a deterministic 4-stage pipeline (snapshot → diff → impact → AI-suggest); every approval is rule-bound and persona-anchored; every action is audited with CSV export.

Only the following are **fictional or randomized** for demo safety: persona names, contractor entity names, specific CVE identifiers, ATO record IDs, POA&M IDs, audit run IDs.

§0 · Team roles for the demo

Abhinav Dharmapuri (ATC) · drives the screen-share — main demo presenter. Walks the 12-step flow at the pace defined in §3. Owns the narrative beats per phase.

Joseph (ATC · cyber security expert · 40+ yrs federal across multiple agencies including the Pentagon) · chimes in for technical depth — observes with Abhinav · camera on, mic muted by default · speaks when the SCA asks technical depth-questions or invokes a competitor by name (ServiceNow CCM, Splunk SOAR, etc.).

Misbah Baig (Azaar Solutions · President · azaarsolutions.com · partner) · opens with the intro + handles post-demo logistics — relationship-holder with Ali Arshed · introduces the team · runs the dry-run with Abhinav + Joseph · does NOT drive demo phases.

Demo audience (Tue 5 May 2026): Vincent (DoD GRC Chief) · the SCA (Security Control Assessor on Ali's team · returns from leave) · Ali Arshed (DoD CIO · already saw the first call).

Demo URL: `https://auctorgrc.vercel.app` · pill `POC` · `v3.0.9` · alias bound to deploy `auctorgrc-osrz9bpoh`.

§1 · What this demo proves

In thirty minutes, the audience will see:

1. **TRUE multi-tenant DoD hierarchy** (the headline · Misbah's CFPB-pattern feedback) — DoD → Office → Sub-office → Project → POA&M as a 5-level navigable drill. Click any of the 5 office cards (DISA · ARCYBER · AF OCIO · NAVIFOR · DoD OIG) and the **entire dashboard re-scopes in <200ms** — every widget honors the office scope · each tenant feels like its own self-contained Auctor.GRC deployment.
2. **Continuous-drift triage with autonomy spine** — when NIST publishes a control catalog amendment mid-cycle, Auctor's drift engine detects the delta, computes downstream impact across the portfolio, drafts AI-suggested remediation actions with confidence scores, and queues them for human approval. Approval rules are persona-anchored. Every step is rule-bound, transparent, and audited. CSV export of the audit log is one click.
3. The Risk Management Framework's six steps (Categorize → Select → Implement → Assess → Authorize → Monitor) surfaced as the navigation spine of the application — not buried inside workflow tasks.
4. AI-driven gap analysis from an architecture diagram → NIST 800-53 controls → a downloadable evidence package — completing in under thirty seconds for a typical sample.
5. The complete RMF triad (System Security Plan + Security Assessment Report + Plan of Action & Milestones) as cross-linked, navigable artifacts — not three siloed documents.
6. An eMASS Authorization Package Studio that pre-stages the bundle, captures Security Control Assessor and Authorizing Official signatures, and submits via a four-stage flow to the eMASS system of record.
7. A Continuous Monitoring schedule engine with per-control assessment cadence, SLA-breach warnings, and AI-recommended cadence tuning.
8. An ATO Lifecycle Tracker that auto-generates renewal POA&M items six months before each ATO expires.
9. Closed-loop CVE/anomaly → POA&M synthesis: when a CVE event arrives via Tenable, a POA&M item is auto-correlated, control-mapped, and persisted in under one second.
10. **Live federal-data attribution** — NIST OSCAL controls catalog, NVD CVE feed, Congress.gov §1512/§1513, Federal Register notices, and FedRAMP Marketplace are all plumbed through with inline source-attribution chips.
11. A persona switcher demonstrating the role-based access control (RBAC) model — what the GRC Chief sees, what the Security Control Assessor sees, what each role can sign.
12. **Per-project rubric scoring with the configurable ATO-ready gate** (v3.0.10 · Misbah's CFPB-pattern moment). Every project surfaces a big-number "X% ATO-ready" headline

derived from 5 weighted criteria — control coverage (30%) · artifact submission (25%) · POA&M closure (25%) · audit remediation (15%) · ConMon attestation (5%). Five closure stages roll up the lifecycle phase: draft → in-review → ato-ready → ato-granted → closed. The ATO-ready threshold (default 80%) is configurable per office via the same

Thresholds popover that holds the RAG sliders. Drag the slider · the headline re-buckets in <100ms without a page reload. **This lands her exact "Qualys shows you're at 80%" moment.**

The audience leaves with a clear answer to the question **"how is this different from incumbent ConMon platforms?"** — Auctor is **the system of action** sitting on top of the federal stack: AI-native gap analysis, continuous-drift autonomy, mandate marketplace, AI-policy surface, eMASS Studio. Workflow-engine ConMon platforms digitize the existing process. Auctor short-circuits the manual reading and mapping work that consumes most of an SCA's week.

§2 · The 30-minute agenda

TIME	BLOCK	DRIVER
0:00 – 2:00	Partner introduction	Partner relationship-holder
2:00 – 5:00	Step 1-2 · Dashboard + multi-tenant DoD hierarchy + 5-level deep drill (the headline)	Lead presenter
5:00 – 8:00	Step 3 · Continuous-drift triage autonomy spine (the second headline)	Lead presenter
8:00 – 22:00	Steps 4-13 walkthrough	Lead presenter
22:00 – 23:30	Persona switcher + role-based access demo	Lead presenter
23:30 – 24:00	Wrap and scheduling	Partner relationship-holder
24:00 – 30:00	Q&A — open	Technical specialist leads SCA-grade questions; lead presenter handles UX/product

The demo wins in the first twelve minutes (steps 1-8) — Dashboard, the **multi-tenant DoD hierarchy + deep drill** (Step 2 · the headline · Misbah's CFPB feedback) , the **continuous-drift triage autonomy spine** (Step 3 · the second headline), RMF, FIPS 199, gap analysis, SAR. After that, slow down and invite questions. **Encourage interruptions early and often.**

Roles by function

- + **Partner relationship-holder** — opens with the introduction, frames the call as the technical session the audience asked for, hands off to the lead presenter, and handles post-demo scheduling and logistics. Does not drive the demo phases.
- + **Lead presenter** — drives every screen-share phase 1-11. Narrates what's happening, anticipates questions, answers UX and product questions directly. Primary microphone for the body of the demo.
- + **Technical specialist** — observes the demo with cameras on and microphones muted. Speaks when (a) a depth question is raised that the lead presenter cannot answer cleanly,

(b) a competitor product is invoked by name, or (c) RMF process or eMASS mechanics get challenged. Does not drive the demo phases.

+ **Architect** — standby for live fixes (browser-cache clears, Vercel alias rebinds). No code changes during the call.

§3 · The 13-step walkthrough

Each step has the same structure: **click**, **load**, **screenshot**, **what it shows**, **why it matters**.

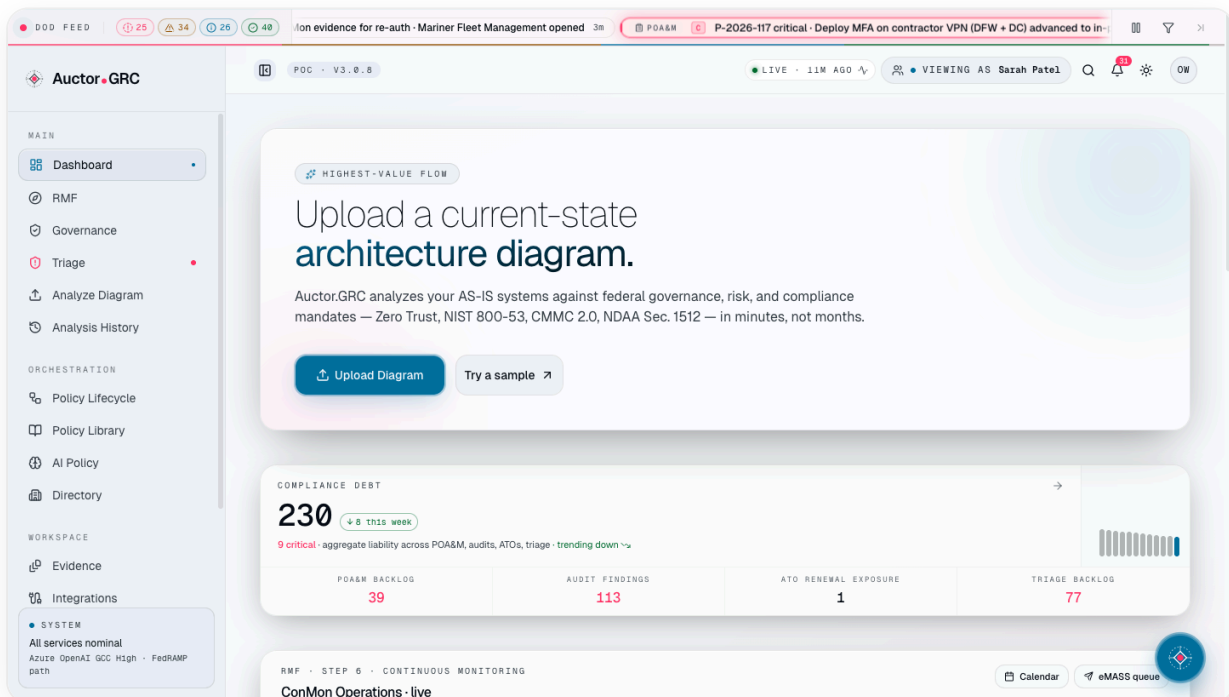
Steps 1–3 carry the demo's two headlines — the multi-tenant DoD hierarchy (Misbah's CFPB-pattern feedback) and the continuous-drift autonomy spine.

Step 1 · Dashboard — orient the audience (1 min)

Click: start at `/dashboard` (already loaded).

Load: the dashboard with the Continuous Monitoring operations scoreboard at the top — five live tiles showing overdue assessments, due-in-7-days, due-in-30-days, active eMASS submissions, and ATOs in renewal-window-open state.

Screenshot:



What it shows: the version pill in the top-left corner reads `POC · v3.0.9`. The DoD Feed live ticker is scrolling along the top of every page — auto-pauses when any modal opens. The sidebar has **15 navigation entries** organized into three groups (Main · Orchestration · Workspace) — RMF promoted to the second item below Dashboard, Triage as the fourth (the autonomy differentiator one click away). The sidebar is intentionally simple — multi-tenant

scope lives in the **top-bar Office switcher chip** (single source of truth · matches the persona-switcher pattern). The Top-bar carries 3 chips: live-data attribution ("live · 4m ago"), Office switcher ("All offices") and persona switcher ("Viewing as Sarah Patel"). Below the ConMon Operations scoreboard with two action CTAs (Calendar · eMASS queue), SLA state surfaces at a glance — Continuous Monitoring is the operational lens, not an afterthought to authorization.

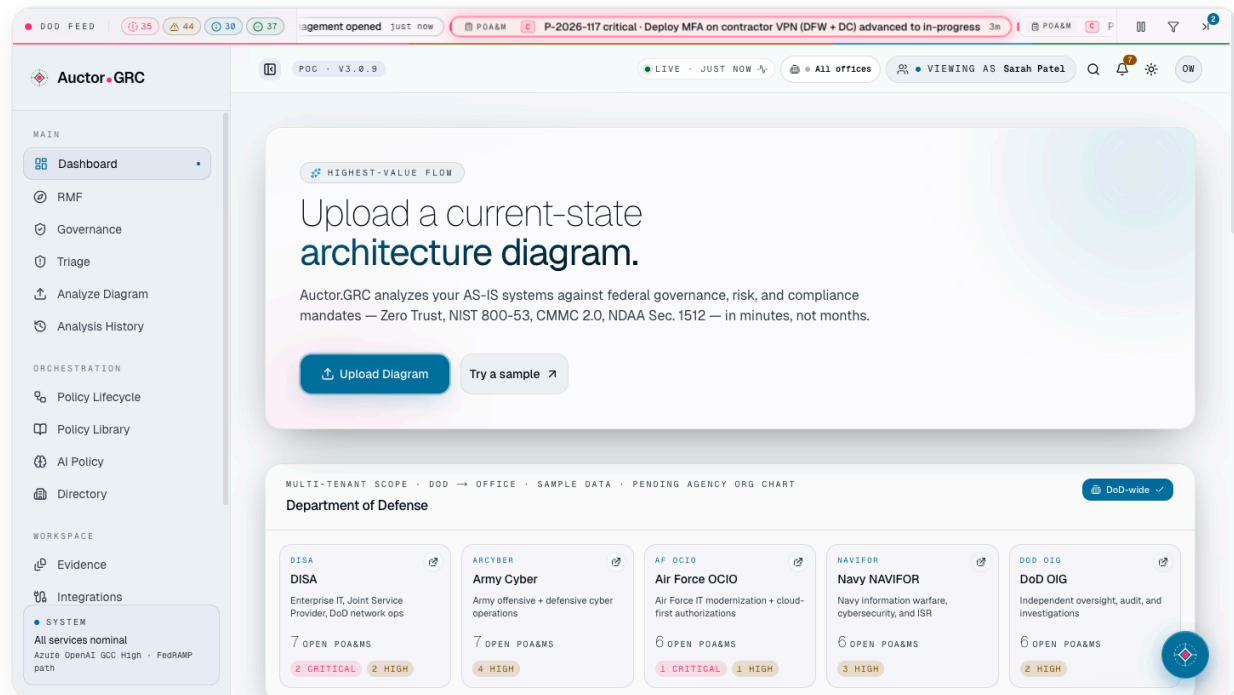
Why it matters: federal cyber teams operate against SLAs, not point-in-time snapshots. A ConMon-first dashboard signals that this product treats continuous monitoring as the primary lens, not as a follow-up to authorization. Vincent (or any GRC Chief) will recognize this layout immediately. **The DoD-shaped office hierarchy directly addresses Misbah's CFPB-pattern feedback: federal users do not scramble through 14 POA&Ms to find theirs — they go to their office.**

Step 2 · Multi-office hierarchy + 5-level deep drill · the federal-shape headline (3 min)

This is the headline of the demo. Misbah's CFPB-pattern feedback in plain English: **"I'm not going to scramble through 14 POA&Ms to find mine. I want to go to my office."** Auctor delivers exactly that — at five levels of depth.

Click 1 of 3 · DoD-wide → office scope: stay on `/dashboard`. Below the hero, find the panel `Department of Defense` with 5 office cards. Click `DISA`.

Load: entire dashboard re-scopes in <200ms — Office chip flips "All offices" → "DISA" · ConMon scoreboard eyebrow flips to "...DISA" · posture gauge re-buckets to DISA controls only · KPI tiles recompute. **Watch the numbers change** (illustrative deltas · narrate the live values, which fluctuate): Compliance Debt POA&M backlog drops ~96 → ~26 · Audit findings ~113 → ~16 · ATO renewal exposure 1 → 0 · Active eMASS bucket drops to 0 · Compliance % ~6% → ~13% · Open Findings ~16 → ~4 · Evidence Packages ~6 → ~2. Every tile shows the live count at demo time — Abhinav reads what's on screen, not the numbers in this guide.



What it proves: every widget honors the office scope · each tenant feels like its own self-contained Auctor.GRC deployment, not a filter over shared data. **NAVIFOR went from 0 active everything (v3.0.8) to 6 POA&Ms · 2 ATOs · 2 audits · 3 projects · 3 sub-offices** — every tenant is real-shaped, not boilerplate.

Click 2 of 3 · office → office detail page: click the external-link icon on the DISA card.

Load: `/dashboard/office/disa` — per-office detail page with: office hero ("Defense Information Systems Agency · DISA · DoD sub-office") · posture summary (100% / 6 controls assessed) · **Sub-offices panel** (3 cards: JSP PEO · CDO · CEO) · **Projects portfolio** (3 cards: Joint Service Provider 2.0 · DISA Cloud Modernization · Enterprise Identity Federation) · **POA&M register · 7 active + 1 closed · ATO portfolio · 4 in flight** (Aerostar API · Logistics Copilot · Contractor VPN · CUI Data Vault) · **Audit register · 5 runs · 2 open · 3 signed-off.**

Auctor.GRC

POC · V3.0.9

LIVE · JUST NOW

All offices

VIEWING AS Sarah Patel

BACK | DASHBOARD | OFFICE | DISA

← Back to dashboard

DISA · DOD SUB-OFFICE

Set global scope to DISA

Defense Information Systems Agency

Enterprise IT, Joint Service Provider, DoD network ops

COMPLIANCE POSTURE · DISA

100% compliant · 6 controls assessed

GREEN · ≥ 85%	AMBER · 60-84%	RED · < 60%
6 / 6 · 100%	0 / 6 · 0%	0 / 6 · 0%

SUB-OFFICES · DISA · SAMPLE DATA · PENDING AGENCY ORG CHART

3 sub-offices within DISA

Joint Service Provider PEO JSP PEO

Program Executive Office for JSP customers · enterprise identity + access modernization

Cyber Defense Operations CDO

DoD network defense · CSP integration · CUI database hardening

Customer Engagement Office CEO

Customer onboarding · authorization sponsorship · ATO renewal coordination

Auctor.GRC

POC · V3.0.9

LIVE · JUST NOW

All offices

VIEWING AS Sarah Patel

BACK | DASHBOARD | OFFICE | DISA

← Back to dashboard

DISA · DOD SUB-OFFICE

Set global scope to DISA

Defense Information Systems Agency

Enterprise IT, Joint Service Provider, DoD network ops

COMPLIANCE POSTURE · DISA

100% compliant · 6 controls assessed

GREEN · ≥ 85%	AMBER · 60-84%	RED · < 60%
6 / 6 · 100%	0 / 6 · 0%	0 / 6 · 0%

SUB-OFFICES · DISA · SAMPLE DATA · PENDING AGENCY ORG CHART

3 sub-offices within DISA

Joint Service Provider PEO JSP PEO

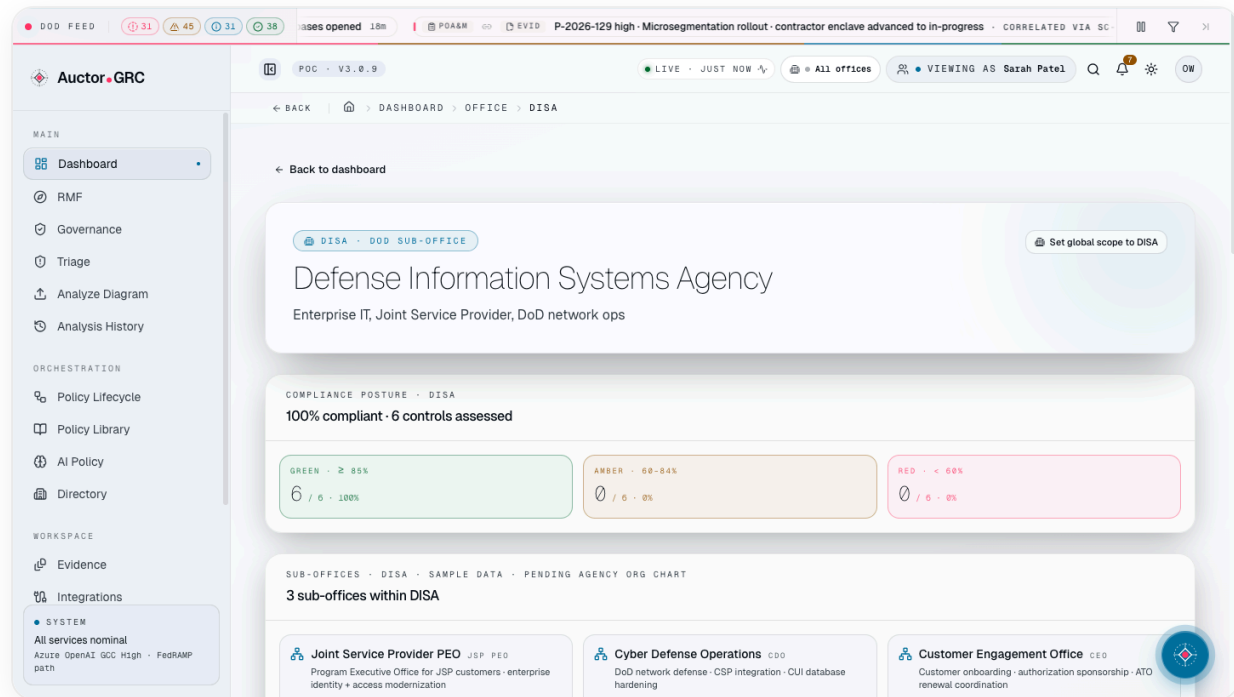
Program Executive Office for JSP customers · enterprise identity + access modernization

Cyber Defense Operations CDO

DoD network defense · CSP integration · CUI database hardening

Customer Engagement Office CEO

Customer onboarding · authorization sponsorship · ATO renewal coordination



Click 3 of 3 · office → sub-office → project (the deep drill): in the Sub-offices panel, click **Joint Service Provider PEO**. Lands on `/dashboard/office/disa/sub/disa-jsp-peo` with breadcrumb `Dashboard / DISA / JSP PEO`, linked project card (**Joint Service Provider 2.0**), and POA&M register scoped to JSP PEO (3 active: P-2026-117 MFA · P-2026-121 SQL TDE · P-2026-180 microsegmentation).

The screenshot displays the Auctor.GRC V3.0.9 web application. The top navigation bar includes a 'DOD FEED' with status indicators (30, 35, 32, 48), a 'Mariner Fleet Management opened' notification, and a 'POA&M' section with a critical item: 'P-2026-117 critical - Deploy MFA on contractor VPN (DFW + DC) advanced to in-progress 10m'. The user is logged in as 'Sarah Patel' and is viewing the 'All offices' view.

The left sidebar contains the following menu items:

- MAIN
 - Dashboard
 - RMF
 - Governance
 - Triage
 - Analyze Diagram
 - Analysis History
- ORCHESTRATION
 - Policy Lifecycle
 - Policy Library
 - AI Policy
 - Directory
- WORKSPACE
 - Evidence
 - Integrations
 - SYSTEM
 - All services nominal
 - Azure OpenAI GOC High - FedRAMP path

The main content area shows the breadcrumb path: [POC](#) > [V3.0.9](#) > [LIVE](#) > [23M AGO](#) > [All offices](#) > [VIEWING AS Sarah Patel](#). The current view is 'Joint Service Provider PEO' (Program Executive Office for JSP customers - enterprise identity + access modernization). The breadcrumb path is: [BACK](#) > [DASHBOARD](#) > [OFFICE](#) > [DISA](#) > [SUB](#) > [DISA JSP PEO](#).

The project details section shows:

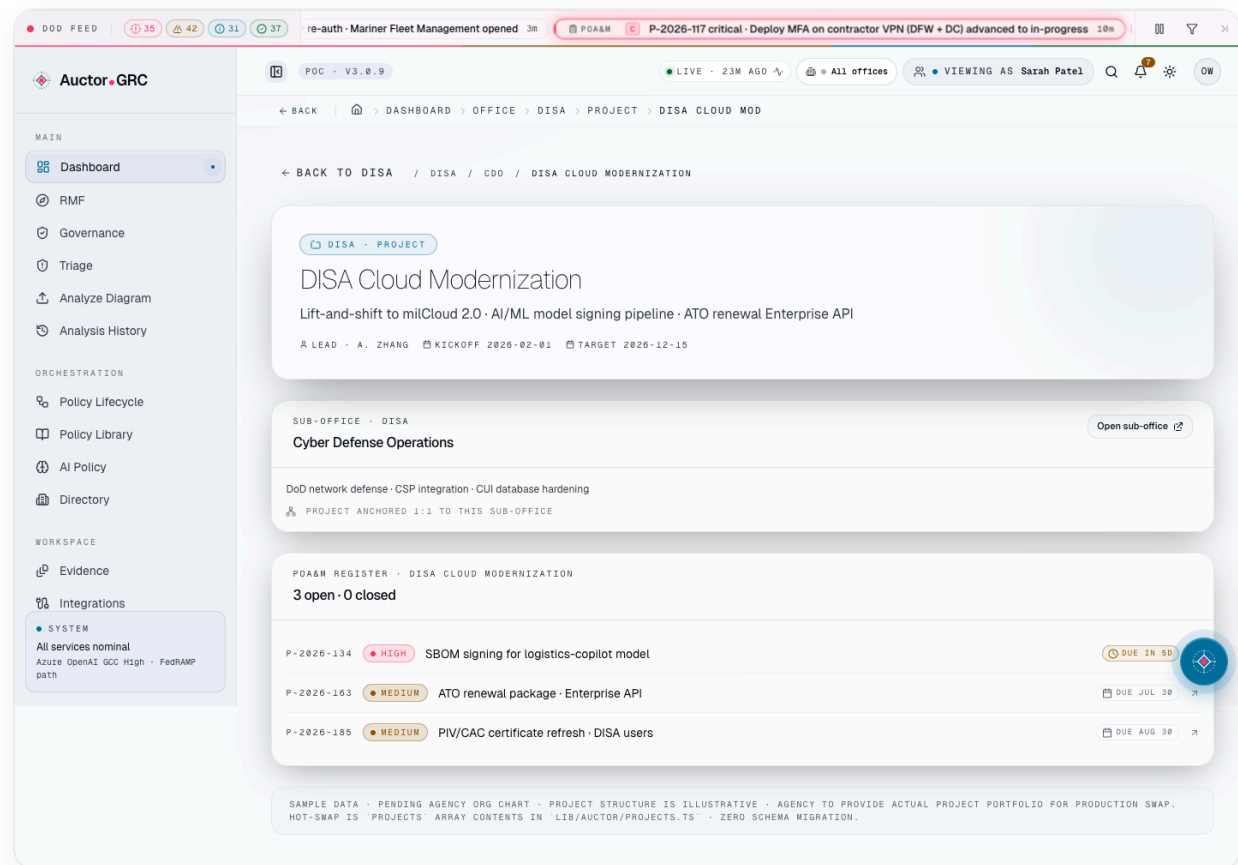
- ACTIVE PROJECT** - JSP PEO
- Joint Service Provider 2.0**
- DISA enterprise identity + access modernization for JSP customers - MFA enforcement - CUI database hardening**
- LEAD** - S. PATEL
- KICKOFF** 2026-01-15
- TARGET** 2026-09-30

The **POA&M REGISTER** for the **JOINT SERVICE PROVIDER PEO** shows 3 open and 0 closed items:

Item ID	Severity	Description	Due Date
P-2026-117	CRITICAL	Deploy MFA on contractor VPN (DFW + DC)	DUE IN 110
P-2026-121	CRITICAL	Enable SQL Server TDE across CUI databases	DUE IN 180
P-2026-180	HIGH	Cloud-One zero-trust pillar 4 - microsegmentation	DUE JUN 28

A sample data note at the bottom states: 'SAMPLE DATA - PENDING AGENCY ORG CHART - SUB-OFFICE STRUCTURE IS ILLUSTRATIVE - AGENCY TO PROVIDE ACTUAL ORG CHART FOR PRODUCTION SWAP. HOT-SWAP IS 'SUBOFFICES' ARRAY CONTENTS IN 'LIB/AUCTOR/OFFICES.TS' - ZERO SCHEMA MIGRATION.'

Click [Open project detail](#) → drill one more level to [/dashboard/office/disa/project/disa-cloud-mod](#) with parent sub-office reverse-link and project-scoped POA&M register (3 tagged via [linkedProjectId](#)).



Why it matters: Misbah's verbatim quote: "is this 13 POA&Ms connected with the bureau, an office, or an individual project?" Auctor answers all three at five levels deep — DoD → Office → Sub-office → Project → POA&M. Every store carries `officeId` (POA&Ms via contractor chain · ATOs · eMASS packages · audits · controls · projects · sub-offices). When DISA hands over their actual org-chart, the swap is `OFFICES` + `subOffices` + `projects` array contents only · **zero schema migration**. The honest "sample data · pending agency org chart" badge sets that expectation in plain text on every per-office page.

Bonus rubric beat (v3.0.10 · 60 sec): when you land on the project detail page (e.g. `/dashboard/office/disa/project/disa-cloud-mod`), the **Project rubric card** at the top shows a big-number "X% ATO-ready" headline. Misbah's exact CFPB pattern: 5 weighted criteria (control coverage · artifact submission · POA&M closure · audit remediation · ConMon attestation) → weighted aggregate → ATO-ready threshold (default 80%). Click **Thresholds** → drag the **ATO-ready slider** to a different value → headline re-buckets in <100ms. Switch the **Apply to** dropdown from "All offices" to a single office to set per-tenant overrides (CFPB might prefer 80% while ARCYBER is happier at 70% — Misbah said this verbatim).

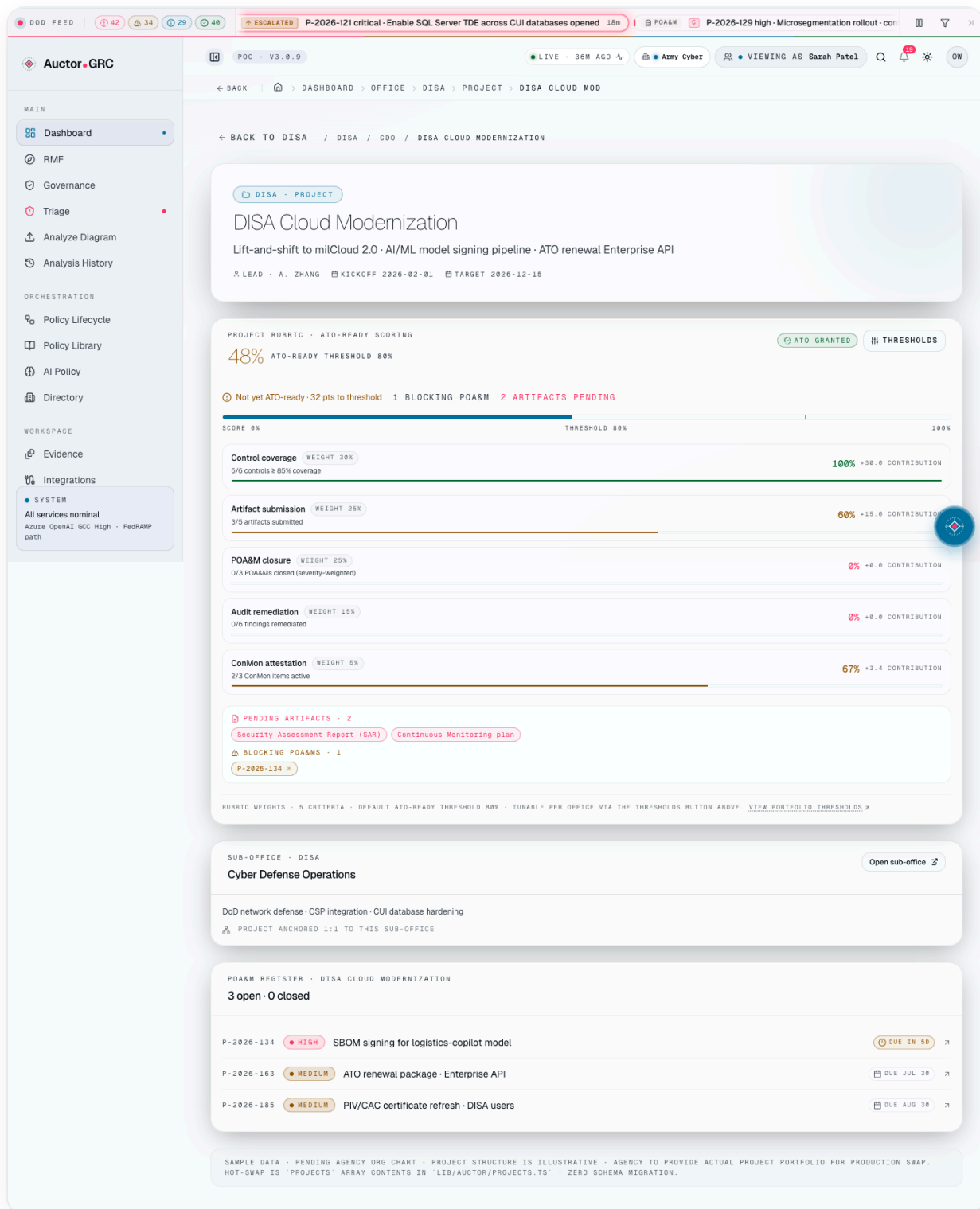
Closure-stage logic (the chip in the top-right of the rubric card):

- + **draft** if rubric score < 50%
- + **in-review** if $50\% \leq \text{score} < \text{ATO-ready threshold}$

- + **ato-ready** if score $\geq$ threshold AND no critical blocking POA&Ms
- + **ato-granted** if the project's `linkedAtoId` is `active` OR `renewal-window-open` (an ATO in renewal-window-open is operationally still granted — the team is just refreshing ConMon evidence for re-auth · this is federal-realistic semantics)
- + **closed** if all conditions met: ATO active · all POA&Ms done · no open audit findings

Live demo angle: navigate to `/dashboard/office/dod-oig/project/oig-cyber-audit` → headline shows "2% ATO-ready · threshold 80% · Draft" with all 5 missing artifacts as red chips. Drag the ATO-ready slider down to 2% → headline flips green "ATO-ready · 2% / 2% threshold met" · stage flips Draft → ATO-ready. **The most dramatic flip moment in the entire demo.** Missing-artifacts list and blocking-POA&M chips link directly to drill pages. **This lands her literal "Qualys shows you're at 80%" moment for DoD.**

Screenshot (DISA Cloud Modernization · ATO granted · 48% rubric):



Screenshot (DoD OIG Cybersecurity Audit · Draft · 2% rubric · the threshold-flip demo target):

Auctor.GRC

MAIN

- Dashboard
- RMF
- Governance
- Triage
- Analyze Diagram
- Analysis History

ORCHESTRATION

- Policy Lifecycle
- Policy Library
- AI Policy
- Directory

WORKSPACE

- Evidence
- Integrations

SYSTEM

- All services nominal
- Azure OpenAI GOC High
- FedRAMP path

POC · V3.0.9

LIVE · 36M AGO

ARMY Cyber

VIEWING AS Sarah Patel

BACK TO DOD OIG / DOD OIG / CAP / DOD-OIG CYBERSECURITY AUDIT

DoD-OIG Cybersecurity Audit

DoD-wide cybersecurity audit program · Ironclad Cyber + Nova Munitions inheritance pattern

A LEAD · R. LEE · KICKOFF 2026-03-05 · TARGET 2027-02-15

PROJECT RUBRIC · ATO-READY SCORING

2% ATO-READY THRESHOLD 80%

DRAFT THRESHOLDS

Not yet ATO-ready · 78 pts to threshold 1 BLOCKING POA&M 5 ARTIFACTS PENDING

SCORE 0% THRESHOLD 80% 100%

Control coverage	WEIGHT 30%	0% +0.0 CONTRIBUTION
0/4 controls ≥ 85% coverage		

Artifact submission	WEIGHT 25%	0% +0.0 CONTRIBUTION
0/5 artifacts submitted		

POA&M closure	WEIGHT 25%	0% +0.0 CONTRIBUTION
0/3 POA&Ms closed (severity-weighted)		

Audit remediation	WEIGHT 15%	0% +0.0 CONTRIBUTION
0/7 findings remediated		

ConMon attestation	WEIGHT 5%	33% +1.7 CONTRIBUTION
1/3 ConMon items active		

PENDING ARTIFACTS · 5

- FIPS 199 categorization
- System Security Plan (SSP)
- Security Assessment Report (SAR)
- POA&M register
- Continuous Monitoring plan

BLOCKING POA&MS · 1

- P-2026-275

RUBRIC WEIGHTS · 5 CRITERIA · DEFAULT ATO-READY THRESHOLD 80% · TUNABLE PER OFFICE VIA THE THRESHOLDS BUTTON ABOVE. VIEW PORTFOLIO THRESHOLDS

SUB-OFFICE · DOD OIG

Cyber Audit Programs

Open sub-office

DoD-wide cybersecurity audit program · inheritance pattern · cross-component oversight

PROJECT ANCHORED 1:1 TO THIS SUB-OFFICE

POA&M REGISTER · DOD-OIG CYBERSECURITY AUDIT

3 open · 0 closed

P-2026-170	LOW	Audit log retention uplift to 7y immutable	DUE AUG 15
P-2026-270 <th>MEDIUM</th> <td>Cyber audit program FY2027 baseline</td> <td>DUE SEP 15</td>	MEDIUM	Cyber audit program FY2027 baseline	DUE SEP 15
P-2026-275 <th>HIGH</th> <td>Whistleblower portal · IL5 hardening</td> <td>DUE JUL 02</td>	HIGH	Whistleblower portal · IL5 hardening	DUE JUL 02

SAMPLE DATA · PENDING AGENCY ORG CHART · PROJECT STRUCTURE IS ILLUSTRATIVE · AGENCY TO PROVIDE ACTUAL PROJECT PORTFOLIO FOR PRODUCTION SWAP. HOT-SWAP IS 'PROJECTS' ARRAY CONTENTS IN 'LIB/AUCTOR/PROJECTS.TS' · ZERO SCHEMA MIGRATION.

Step 3 · Continuous-drift triage · the autonomy mic-drop (3 min)

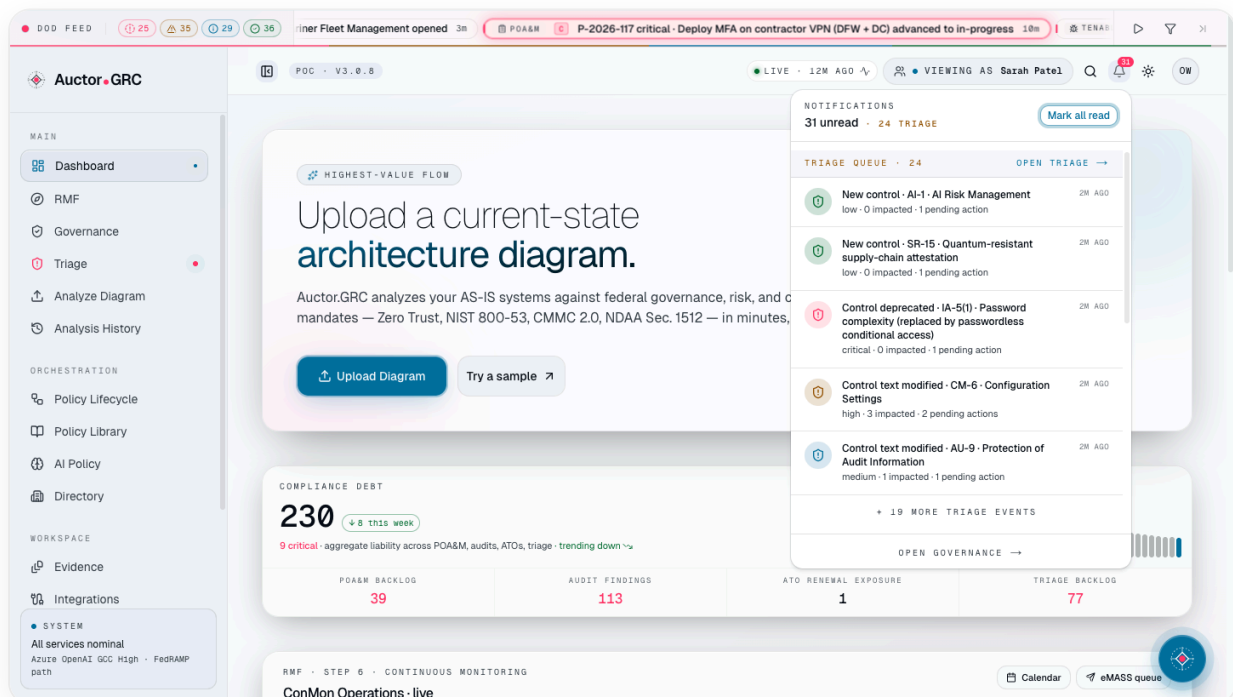
Click: sidebar **Settings** → scroll to "Demo simulator" panel → button **"Simulate NIST 800-53 Rev 5.3 publication"**.

Load: within one second, the simulator injects 12 triage events targeting controls that exist in the seeded portfolio (AC-2 · AC-17 · IA-2 · SC-7 · SC-28 · SI-4 · AU-9 · CM-6 modified · IA-5(1) deprecated · SR-15 + AI-1 added · catalog version bumped to 5.3). The notifications bell at the top-right pulses red. The sidebar's **Triage** entry shows a red pulse-ring badge with the critical count.

A note on the visible queue count. The autonomy mode is the source of truth for what an SCA sees, not the upstream event count. Under the demo default (**MODERATE**), routine drift auto-completes inline and only pivotal actions queue for human review — so the visible queue may show fewer than 12 rows depending on how many events auto-merged with high AI confidence. Under **OFF**, every event lands in the queue. Under **ON**, the queue stays minimal (only the immutable 12-control safety-rail items + SAR/ATO/eMASS-class actions surface). The mode is set on `/governance/triage/rules` and shown live in the page header.

Click: the bell → the consolidated `<NotificationsPopover />` shows two sections: **Triage queue · 12** above **General · 7**, with a combined badge "19 unread · 1 triage critical" rendered on the bell.

Screenshot:



Click: the **Triage queue · 12** header link → routes to `/governance/triage`.

Screenshot:

Auctor.GRC

MAIN

- Dashboard
- RMF
- Governance
- Triage**
- Analyze Diagram
- Analysis History

ORCHESTRATION

- Policy Lifecycle
- Policy Library
- AI Policy
- Directory

WORKSPACE

- Evidence
- Integrations
- SYSTEM
 - All services nominal
 - Azure OpenAI GCC High · FedRAMP path

POC · V3.0.8

LIVE · 11M AGO · VIEWING AS Sarah Patel

GOVERNANCE > TRIAGE

GOVERNANCE · CONTINUOUS-DRIFT TRIAGE

Drift detected. Impact analyzed. Actions proposed.

When upstream federal data sources change — NIST publishes a control update, NDAA gets amended, FedRAMP authorization status flips — Auctor detects the diff, cross-references the impact across your portfolio, and proposes AI-suggested resolution actions. Routine drift auto-resolves; pivotal decisions route to human-in-the-loop.

AUTO · MOD · mod ≥ 70% · LIVE · DRIFT ENGINE · NIST OSCAL · verified 1h ago

CRITICAL 2 HIGH 16 NEW 18 RESOLVED 70

Search by ID, summary, or control

SEVERITY CRITICAL HIGH MEDIUM LOW STATUS NEW TRIAGED IN PROGRESS RESOLVED DISMISSED

Sort: severity

SHOW SELF-REJECTED 4

SYSTEM AUDIT LOG

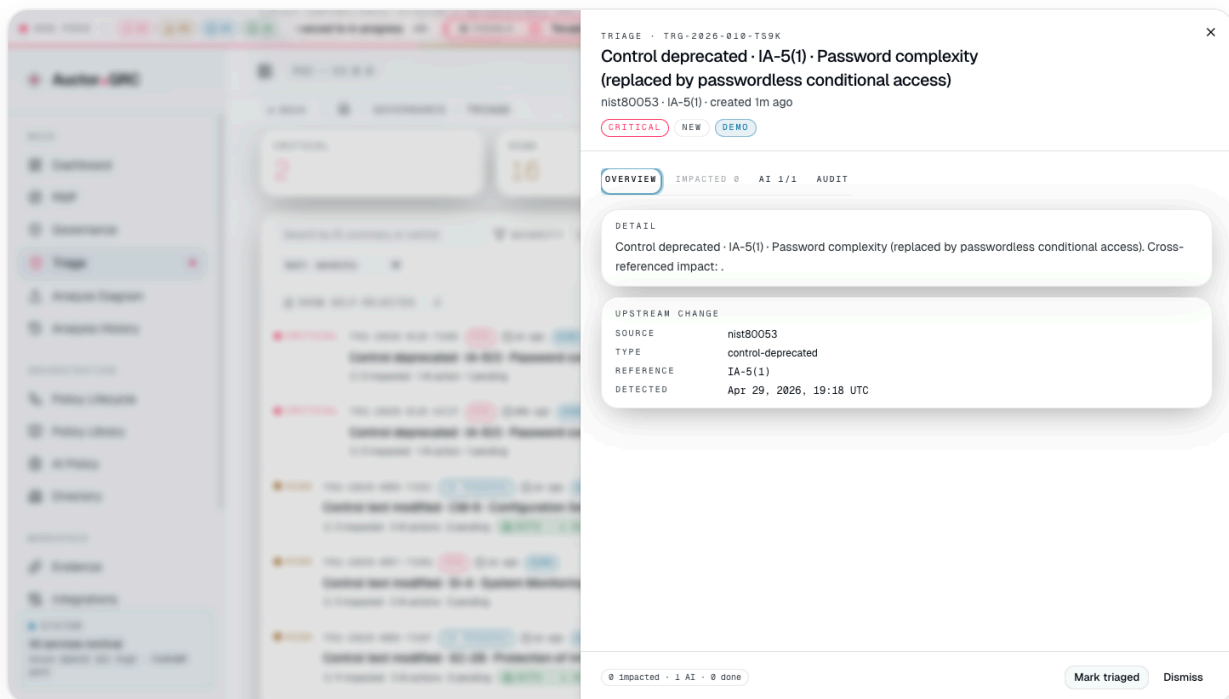
CRITICAL	TRG-2026-010-TS9K	NEW	Just now	DEMO
Control deprecated · IA-5(1) · Password complexity (replaced by passwordless conditional access)				
0 impacted 1 AI action 1 pending				
CRITICAL	TRG-2026-010-4XIP	NEW	45m ago	DEMO
Control deprecated · IA-5(1) · Password complexity (replaced by passwordless conditional access)				
0 impacted 1 AI action 1 pending				
HIGH	TRG-2026-009-TS9I	IN PROGRESS	Just now	DEMO
Control text modified · CM-6 · Configuration Settings				

AI REASONING · LIVE

What it shows: the triage queue lists 12 events sorted by severity. Each row carries (a) the source diff (e.g., "AC-2 control text amended · NIST OSCAL Rev 5.3"), (b) the impact summary (e.g., "8 systems · 4 POA&M items · 1 ATO package affected"), (c) the AI-suggested action with a confidence chip (e.g., "Auto-merge text update · 0.94 confidence"), and (d) the approval state (auto-completed / pending SCA / pending GRC Chief).

Click: any row → drill sheet opens at 768 px (no longer clamped at 384 px after the v3.0.7.3 width unlock · this is the widest drill in the app).

Screenshot:



What it shows: the drill renders the four-stage pipeline (snapshot → diff → impact → AI-suggest) inline. The diff stage shows the actual text delta against the prior snapshot. The impact stage walks the downstream graph — every system, control, POA&M item, and ATO package affected, each as an inverse-link chip. The AI-suggest stage renders the proposed action plus the rule that classified it as auto-merge or approval-required. Approval-required actions are anchored to persona — SAR signatures, ATO grants, and eMASS submissions require the Security Control Assessor; routine POA&M text-merge auto-completes when AI confidence exceeds the rule threshold and no critical control is touched. Click **Approve** (when SCA persona is active) → the action executes against the linked store and emits a ticker event.

Click: `/governance/triage/audit` from the queue header.

What it shows: a full audit log of every triage event, every AI suggestion, every auto-completion, and every human approval — including the persona, the timestamp, the rule that fired, and the resulting state change. **Export to CSV** is one click. This is the artifact the Authorizing Official will ask for during pre-grant review.

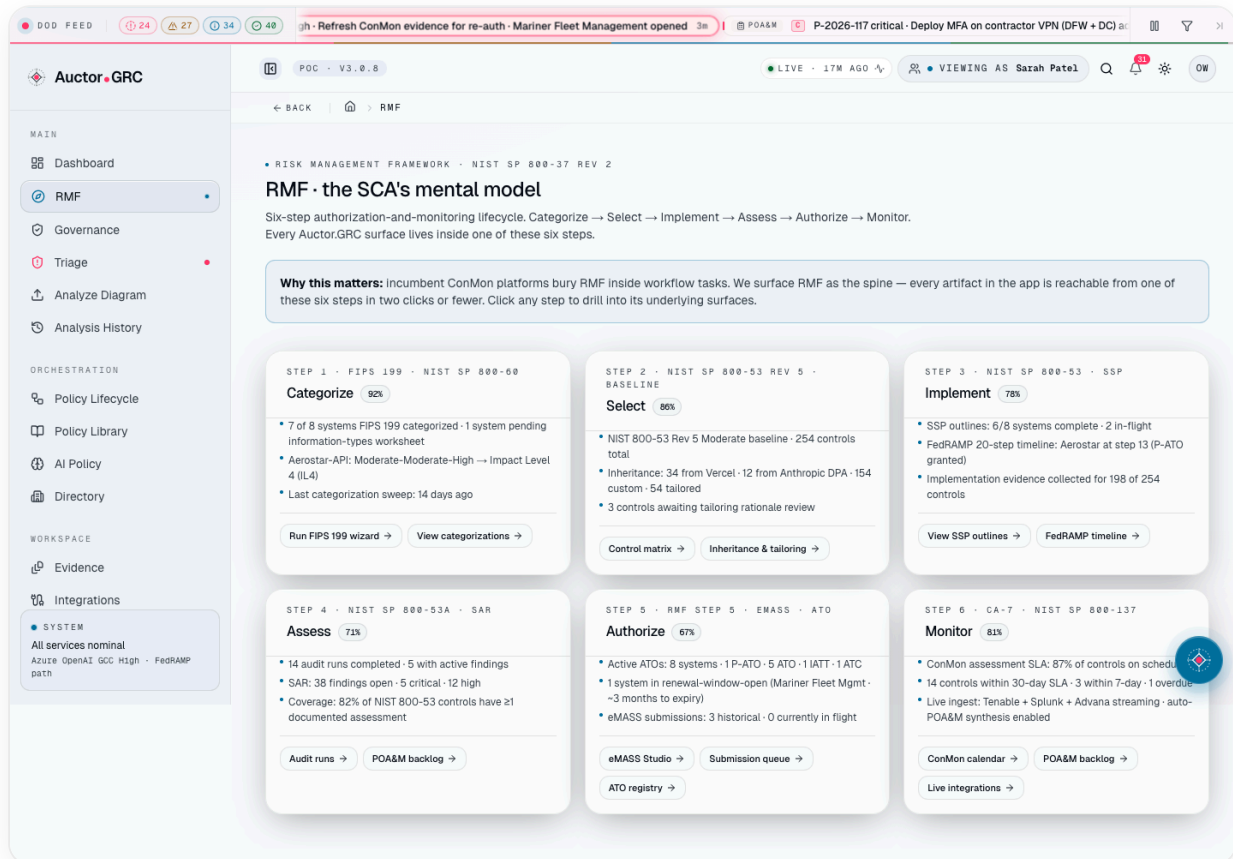
Why it matters: this is the answer to **"what does AI-native continuous authorization actually look like?"** AI doesn't take unilateral action — every suggestion is **transparent** (the diff is visible), **rule-bound** (the classification rule is named), **human-reviewable** (approval anchored to persona), and **audited** (CSV export of the full chain of custody). Workflow-engine ConMon platforms route tasks. Auctor closes the loop — drift → impact → suggested action → approval → audit. The autonomy spine runs on **your** rules, not ours.

Step 4 · RMF 6-step navigator (1.5 min)

Click: sidebar **RMF** (second item).

Load: `/rmf` — six cards arranged in a 3×2 grid, one per RMF step.

Screenshot:



What it shows: the six steps of NIST SP 800-37 Rev 2 — Categorize, Select, Implement, Assess, Authorize, Monitor — each with a **per-portfolio completion percentage tied to live state**. The values fluctuate as POA&Ms close, audits sign off, and ATOs renew; the SCA will see the actual numbers at demo time, not snapshot values. Each card lists the relevant NIST publication reference, three lines of summary state, and 2-3 quick-link CTAs to the surfaces that operate inside that step.

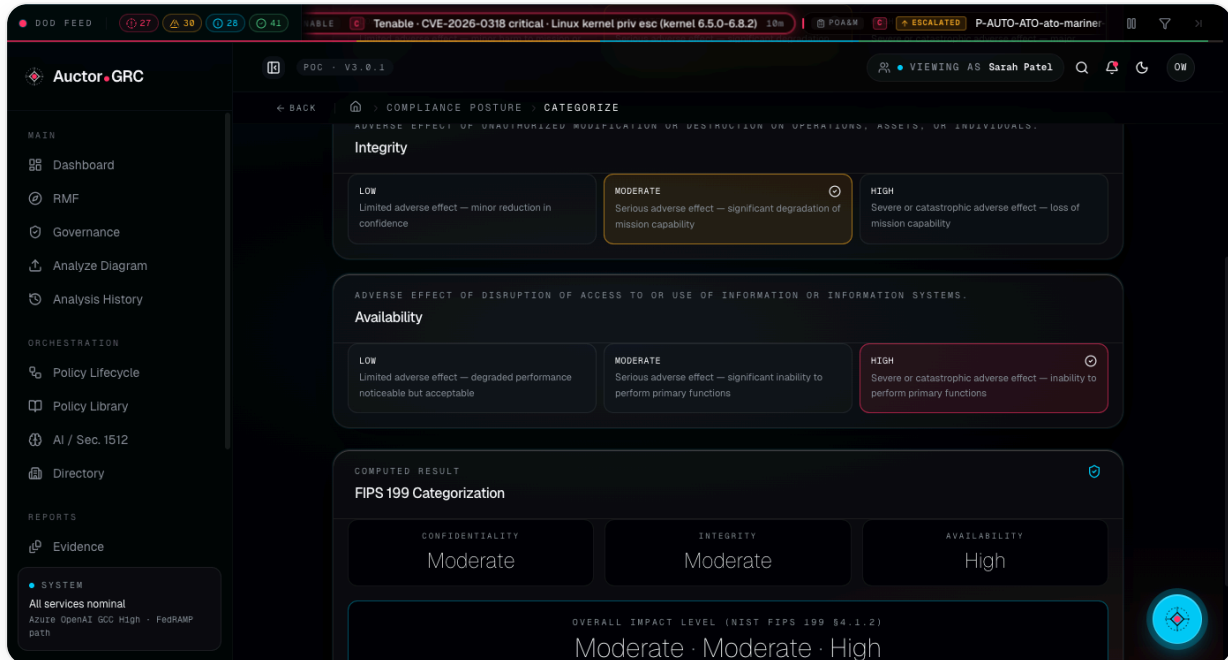
Why it matters: the Security Control Assessor and the GRC Chief think in RMF six steps. Incumbent ConMon platforms bury RMF inside workflow-task hierarchies. Auctor surfaces RMF as the navigation spine — every artifact in the application lives explicitly inside one of these six steps.

Step 5 · FIPS 199 categorization wizard (1 min)

Click: RMF Step 1 card on `/rmf` → "Run FIPS 199 wizard".

Load: `/compliance-posture/categorize` — the FIPS 199 wizard with three vertical scales (Confidentiality, Integrity, Availability), each offering Low / Moderate / High.

Screenshot:



What it shows: rate each of the three scales. The result is computed live as the maximum of the three (the canonical FIPS 199 §4.1.2 formula). For Moderate-Moderate-High, the result is High → IL5/IL6 (DoD Cloud Computing SRG mapping for mission-critical CUI or classified). The "Apply to system" CTA writes the categorization back to the SSP.

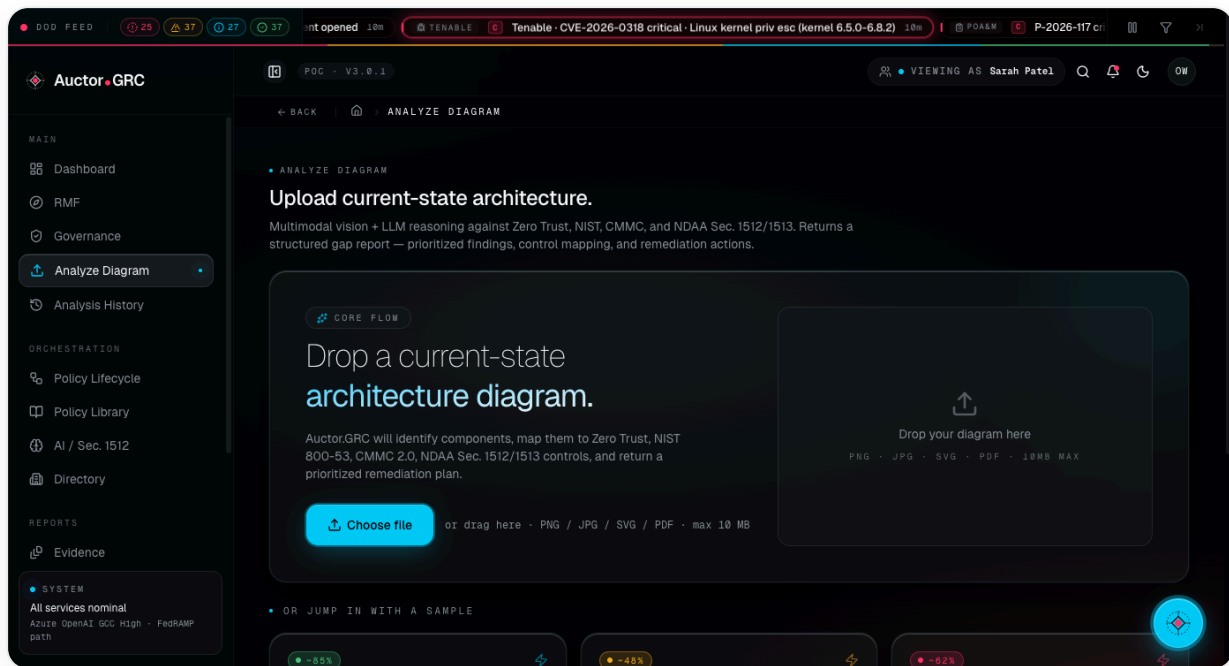
Why it matters: RMF Step 1 is where every authorization journey begins. An interactive wizard turns a 90-second process into a coachable workflow that a junior assessor can complete with confidence. The IL mapping is a real DoD convention — not Auctor terminology.

Step 6 · Architecture-to-control gap analysis · the AI moment (3 min)

Click: sidebar `Analyze Diagram` → choose a sample (Well-architected enterprise API, Contractor enclave gap path, or OT/weapon system).

Load: `/upload` showing three pre-built sample architectures with applicable framework chips.

Screenshot:



What it shows: the upload landing page with three pre-built sample architectures, each tagged with the frameworks it tests against (Zero Trust 2.0, NIST 800-53, CMMC 2.0 L2, NIST 800-171, NDAA Sec. 1512, etc.). Click any sample → the AI vision-and-reasoning engine extracts components, maps each to NIST 800-53 control families, runs gap analysis, and returns a structured report with risk score, family heatmap, prioritized findings, and a downloadable evidence package.

Why it matters: this capability does not exist in any incumbent ConMon platform.

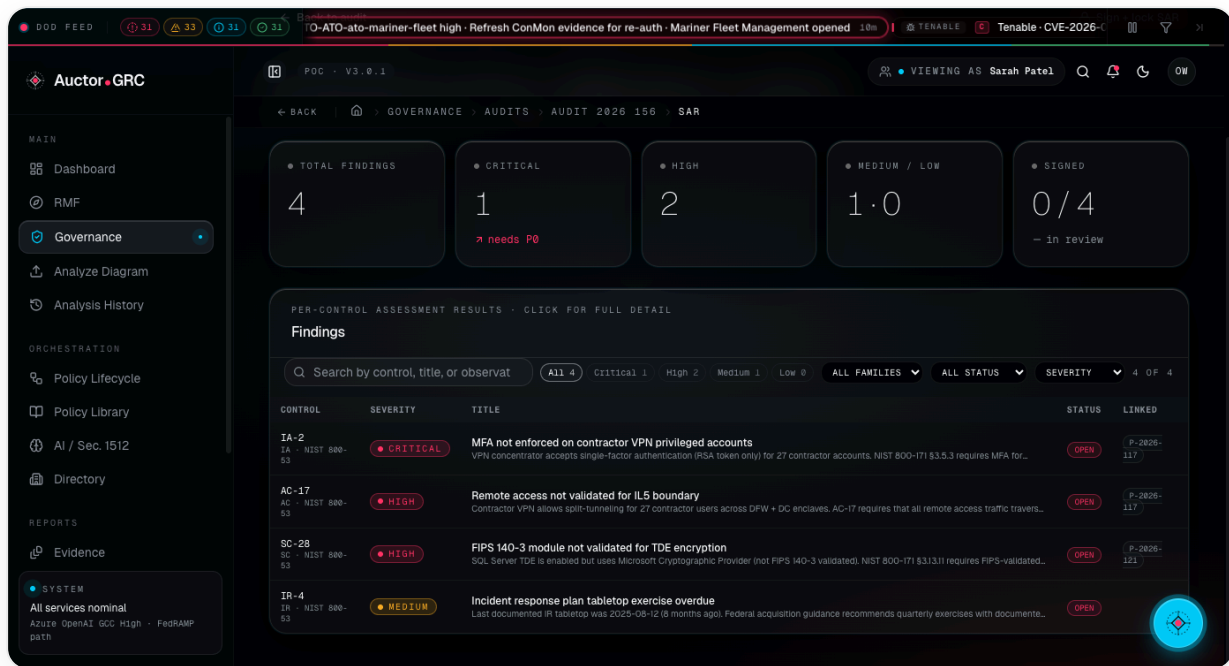
Workflow-engine ConMon products digitize the existing RMF process. Auctor short-circuits the most expensive part of the process — the manual reading and mapping work that consumes most of an SCA's week — into an AI-driven loop that produces structured output an SCA can review rather than draft.

Step 7 · SAR — the third leg of the RMF triad (2 min)

Click: sidebar `Governance` → `/governance/audits` → most-recent audit run → primary CTA "View SAR".

Load: `/governance/audits/[id]/sar` — the Security Assessment Report surface with a 5-tile KPI strip, severity filter chips, family filter, status filter, and a finding list.

Screenshot:



What it shows: each finding has a control ID (e.g., AC-2, SC-13), a severity badge (Critical / High / Medium / Low), a title, and a status. Filters along the top let an assessor cut to the findings that matter for the current review pass.

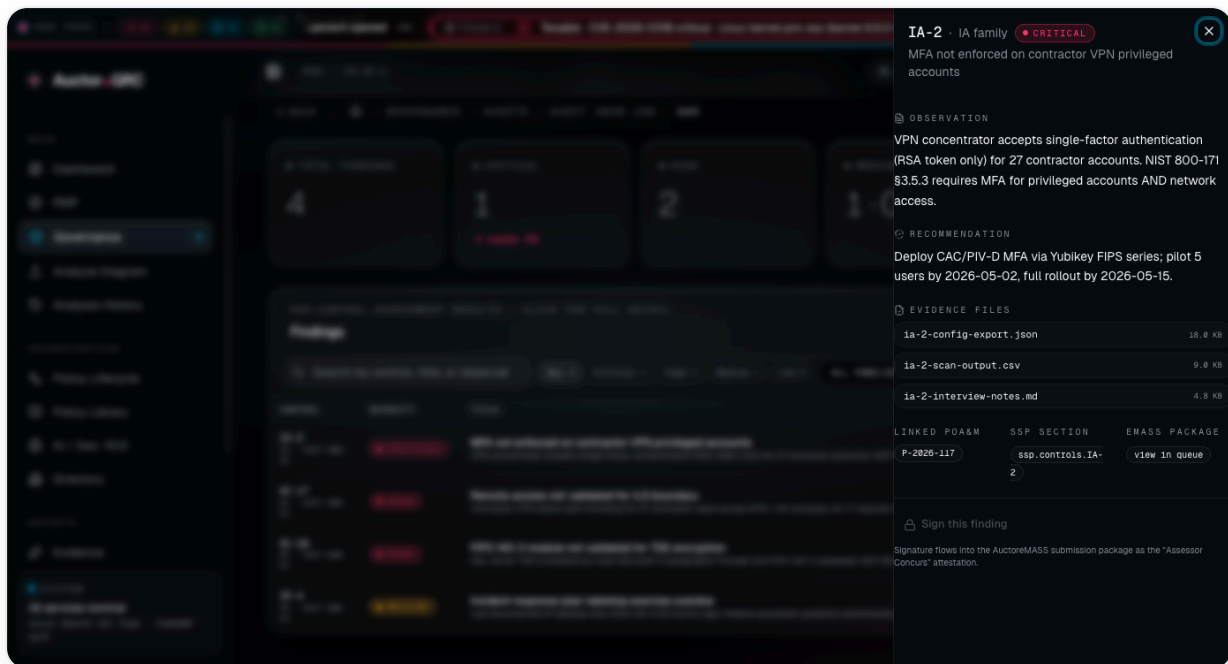
Why it matters: in the Risk Management Framework, the System Security Plan + the SAR + the POA&M are the three documents that together justify an ATO grant. Until v3.0, Auctor had SSP and POA&M but no first-class SAR surface — the second leg of the RMF triad. Adding SAR as a navigable artifact (not a workflow task) closes the credibility gap with the SCA.

Step 8 · SAR finding detail · evidence + cross-links (1.5 min)

Click: any finding row in the SAR list from Step 7.

Load: a sliding sheet with the full finding detail — observation, recommendation, evidence files, linked POA&M items, SSP section reference, eMASS package reference.

Screenshot:



What it shows: the finding's narrative observation (what the assessor saw), the recommendation (how to remediate), evidence files (mock-attached for the demo), and three cross-link chips connecting the finding back to its POA&M item, the SSP section that documents the control implementation, and the eMASS submission package that will roll up this finding. A "Sign + lock" CTA appears at the bottom — gated by the SCA persona's permissions.

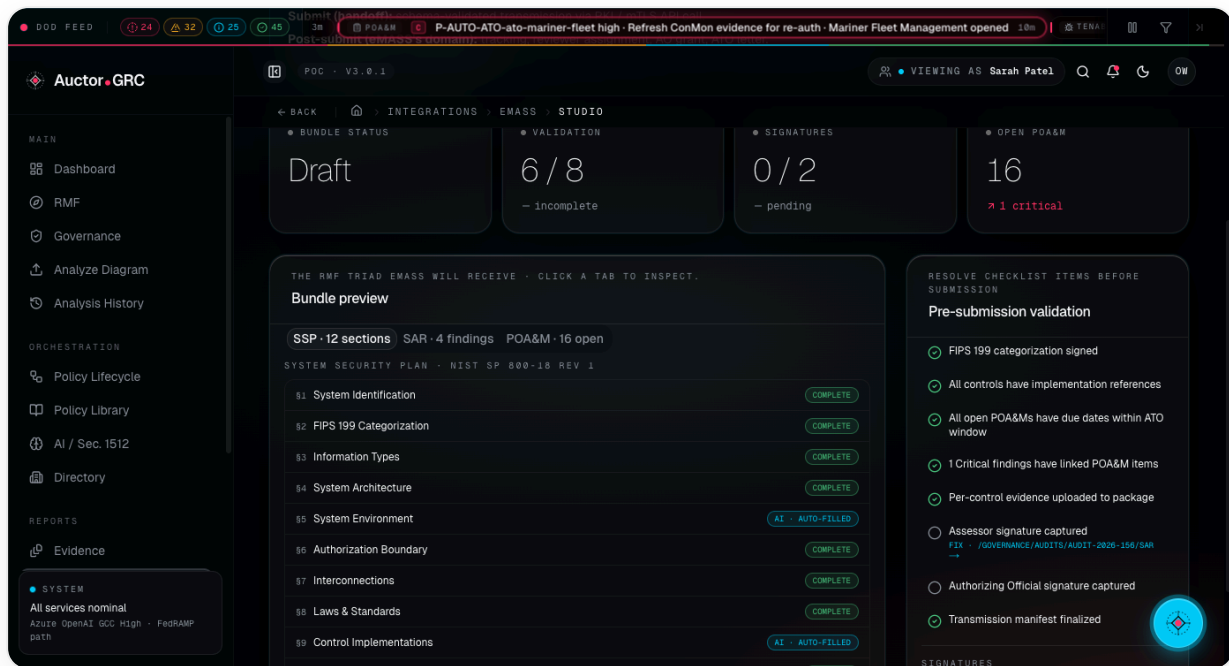
Why it matters: the SCA's daily reality is reviewing findings one at a time and signing them off. A surface that mirrors this workflow — observation, recommendation, evidence, cross-link, sign — turns the SAR from a document into an operational tool.

Step 9 · eMASS Authorization Package Studio · the bundle workspace (3 min)

Click: sidebar `eMASS Studio` (a direct entry in the Workspace group).

Load: `/integrations/emass/studio` — the Authorization Package Studio with a manuscript-layout bundle preview (three tabs: SSP, SAR, POA&M) on the left and a validation panel on the right.

Screenshot:

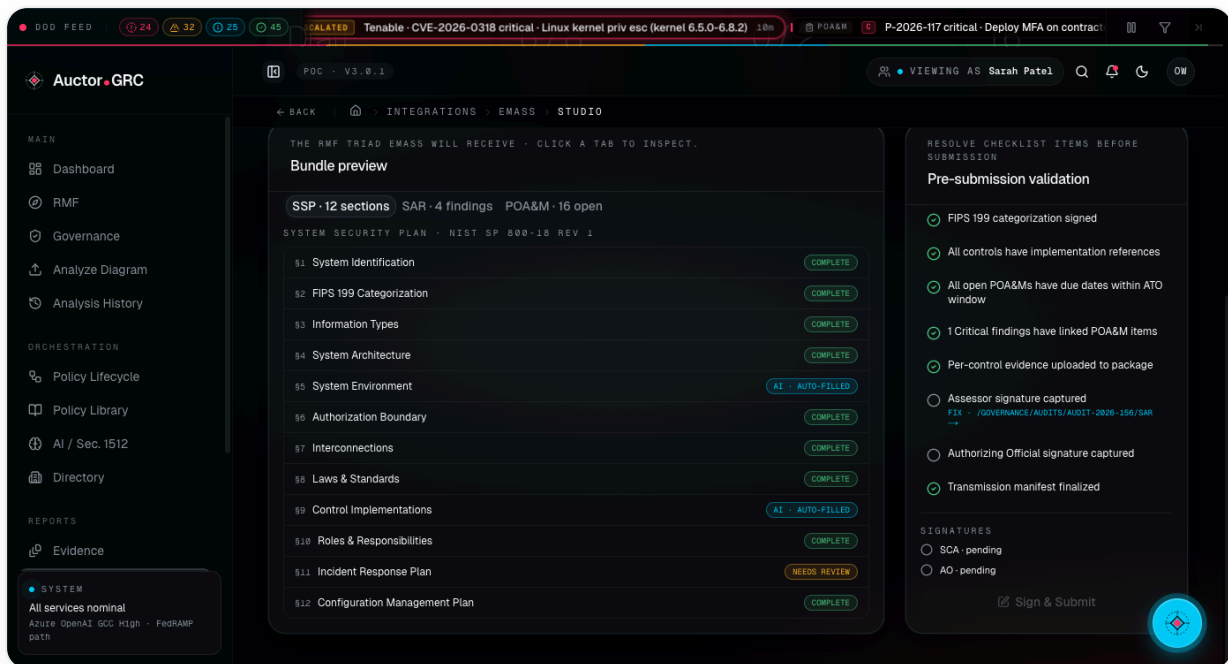


What it shows: the framing line at the top of the page: **eMASS is the system of record.**

Auctor is the system of action. An expandable details block explains the four-zone breakdown — pre-submit (Auctor's domain), submit (the API handoff), post-submit (eMASS's domain), post-ATO (back to Auctor for continuous monitoring).

The **SSP tab** lists all 12 NIST SP 800-18 sections with status chips (complete / auto-filled / needs-review). The **SAR tab** joins to the audit run from Step 6 and shows finding count + severity breakdown. The **POA&M tab** rolls up open POA&M items linked to this submission.

Screenshot:



The right-rail validation panel shows a checklist (item count tied to bundle state · typically 4-8 items per package). Items in the unchecked state get a "Fix" deep-link CTA that jumps directly to the surface where the missing artifact lives. When every item passes, the **Sign & Submit** button activates.

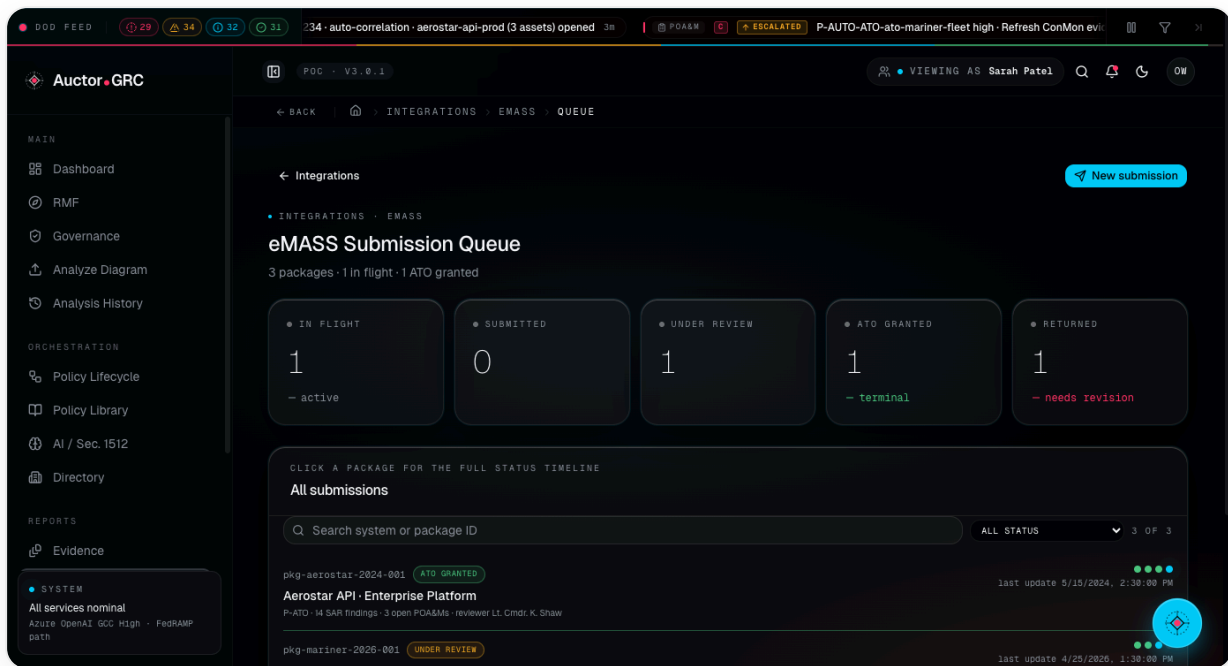
Why it matters: this answers the most important question federal cyber teams ask of any new ConMon platform — **"how does this differ from eMASS?"** eMASS is the system of record where authorization packages are tracked once submitted. Auctor is the system of action where packages are pre-staged, validated, signed, and transmitted. The two are complementary, not competitive.

Step 10 · eMASS submission queue · status callback (1 min)

Click: after Sign & Submit completes, auto-redirect to `/integrations/emass/queue`.

Load: the submission queue showing every package with its current status and a 4-dot timeline.

Screenshot:



What it shows: three historical packages from the seed data (one ATO Granted, one Under Review, one Returned for Revision). The newly-submitted package starts at Submitted and auto-advances over 28 seconds — Reviewer Assigned at 4 seconds, Under Review at 12 seconds, ATO Granted at 28 seconds. Each transition emits a live ticker event.

Why it matters: in production this represents the real eMASS callback over hours or days. The compressed timeline shows the lifecycle without making the audience wait. Vincent or the SCA sees the lifecycle they live in, just sped up.

Step 11 · Marketplace install + §1512/1513 in one beat · live federal data (2 min)

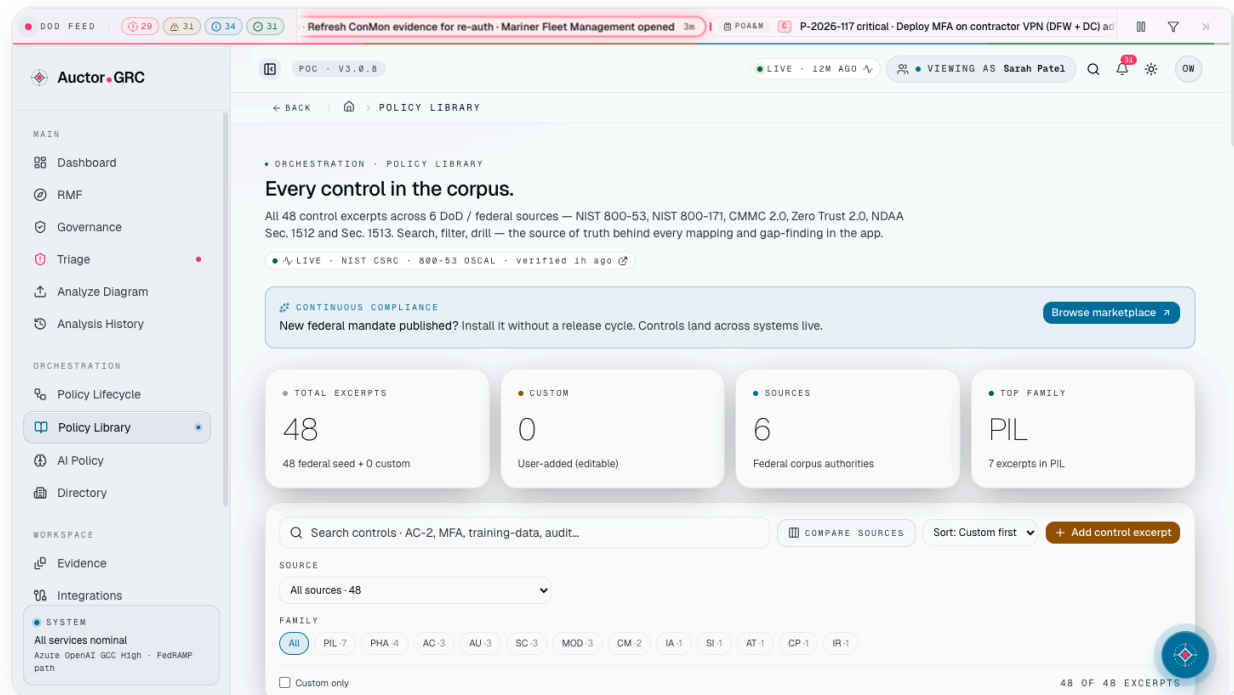
Click: sidebar `Policy Library` (then "Browse marketplace") OR the top-bar `LIVE` indicator chip to expose the source-attribution panel.

Load: `/policy-library` shows the federated mandate library backed by **five live federal data sources** — default ON since v3.0.9 (use `?live=off` for offline-mode rehearsal):

- + **NIST OSCAL controls catalog** — 324 NIST 800-53 Rev 5 controls, refreshed daily
- + **NVD CVE feed** — 200 most recent critical/high vulnerabilities
- + **Congress.gov NDAA** — Sections 1512 + 1513 full text via server-side proxy (browser never sees the data.gov key)
- + **Federal Register** — 30 most recent cyber-related rule notices
- + **FedRAMP Marketplace** — 309 currently-authorized cloud service offerings

Counts shown reflect live federal data as of the demo session; numbers vary daily as new authorizations land in FedRAMP, new CVEs publish to NVD, and Federal Register notices roll forward. The presenter should hard-reload the page at T-15 min and verify the displayed counts before the audience sees them — then narrate the actual numbers, not the numbers in this guide. **"The POC never claims provenance it cannot demonstrate."**

Screenshot:



What it shows: live data is surfaced two ways — the **top-bar LIVE chip** opens a popover naming all 5 sources with their current freshness (NIST OSCAL, NVD, Congress.gov, Federal Register, FedRAMP), and **per-source <LiveAttribution> chips** appear inline on policy-excerpt drill pages. The marketplace refreshes every 24 hours. Each tile has an Install button. Clicking install runs a 4-stage flow (Fetch → Parse → Map → Apply) — controls are derived, mapped to systems in the asset registry, and POA&M items are created for each newly-flagged gap.

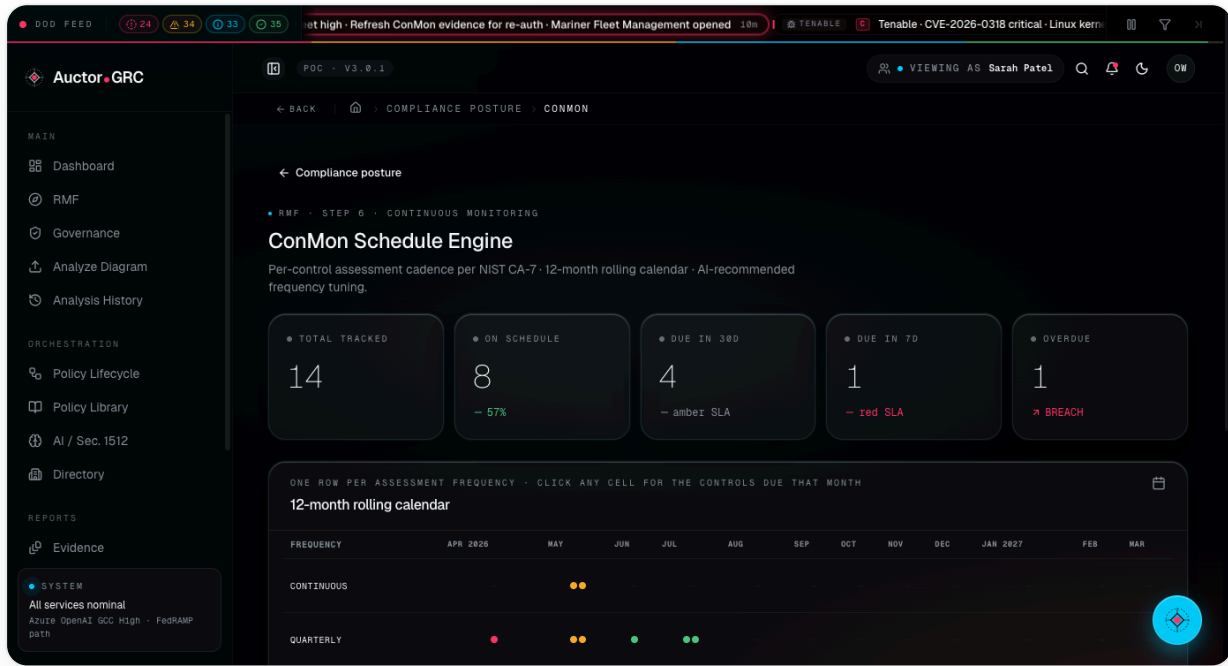
Why it matters: mandates take six months on average to propagate from publication to system-level enforcement. The marketplace cuts that to under five minutes. **Section 1512 lives in this same marketplace** — installable as soon as the draft publishes, so the moment §1513 enforces, the team is already ahead of the flag. And because the data is **live**, not seeded, the SCA can verify the count, the date, and the upstream URL without leaving the app. **"The POC never claims provenance it cannot demonstrate."**

Step 12 · ConMon Schedule Engine + AI tuning (2 min)

Click: sidebar `Compliance Posture` → "ConMon calendar".

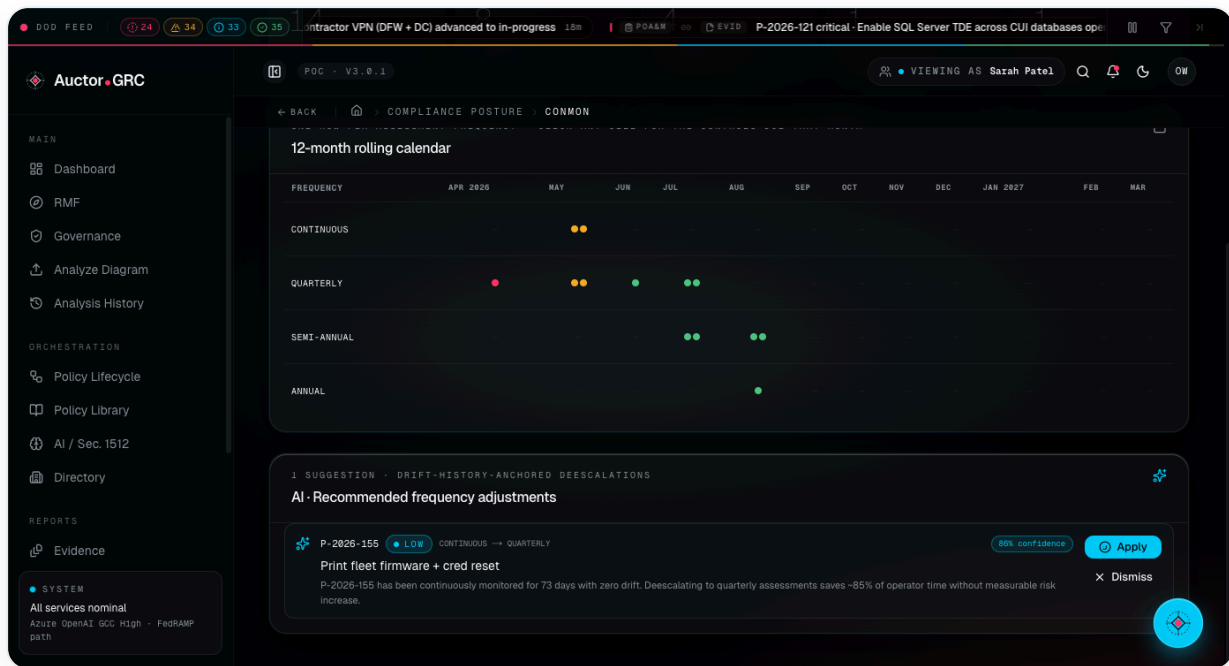
Load: `/compliance-posture/conmon` — the 12-month rolling calendar with frequency rows.

Screenshot:



What it shows: a 12-month rolling grid with one row per assessment frequency (continuous, quarterly, semi-annual, annual). Each cell shows controls due for assessment that month as colored dots. Click any cell with dots → flyout listing the controls due. SLA breach states are color-coded — green for on-schedule, amber for due-in-30-days, red for due-in-7-days, deep-red-with-pulse for overdue.

Screenshot:



What it shows: below the calendar, the AI tuning panel surfaces deescalation recommendations. Example: **"AC-2 has been continuously monitored for 247 days with zero drift. Deescalating to quarterly assessments saves ~85% of operator time without measurable risk increase."** Each recommendation has a confidence score and an Apply CTA.

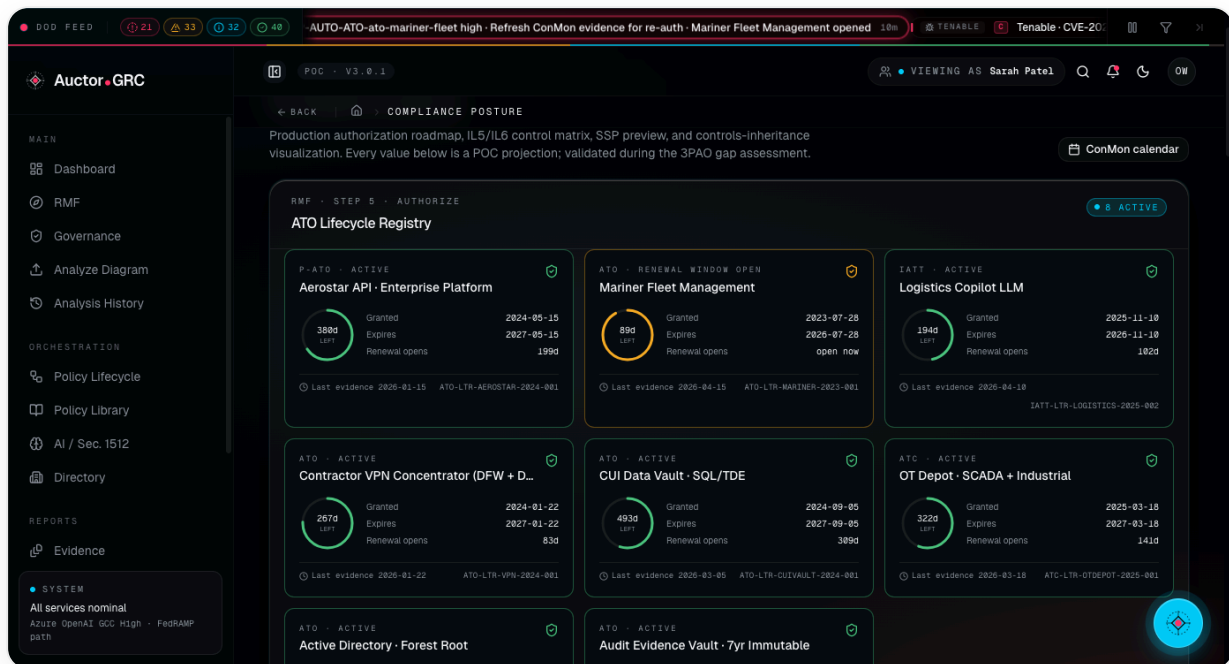
Why it matters: continuous monitoring is what every federal cyber program is moving toward. Workflow-engine ConMon platforms manage the calendar. **Auctor manages the calendar plus the AI-driven cadence tuning.** That's the differentiation an SCA notices.

Step 13 · ATO Lifecycle + Tenable closed-loop (2 min)

Click: sidebar **Compliance Posture** → ATO Lifecycle Registry strip at the top.

Load: `/compliance-posture` showing 13 ATO tiles, distributed across 5 offices (DISA 4 · ARCYBER 3 · AF OCIO 2 · NAVIFOR 2 · DoD OIG 2).

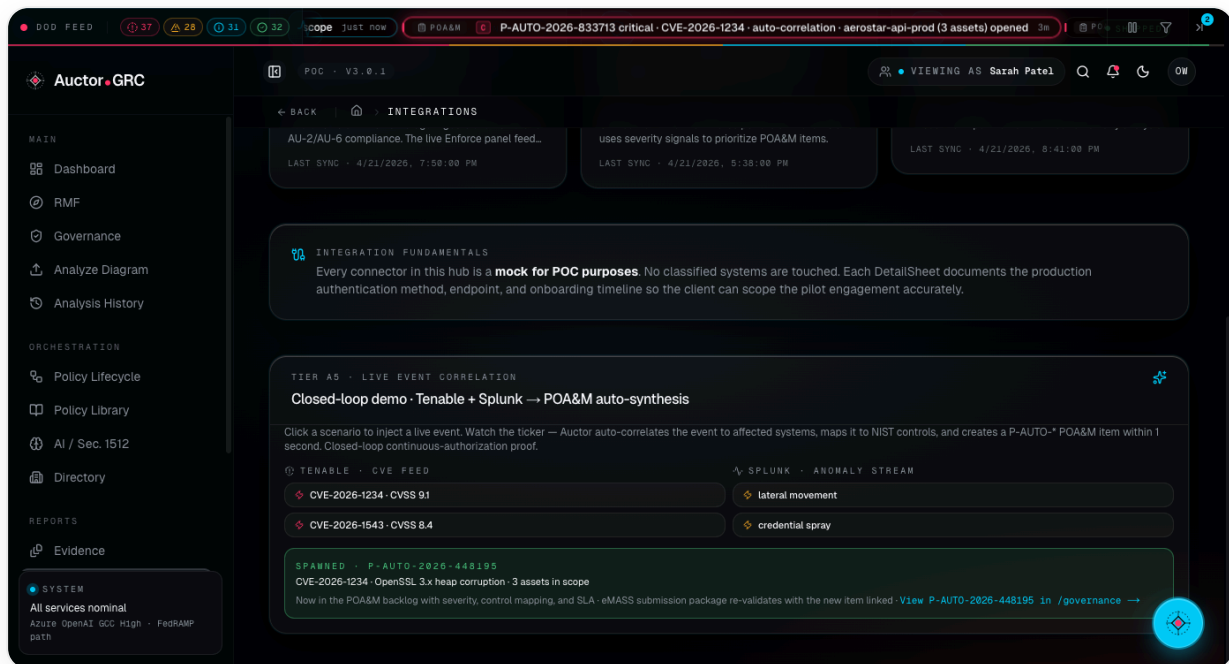
Screenshot:



What it shows: each tile has a countdown ring (3-year window visualized as stroke-dashoffset progress), the ATO type (ATO · P-ATO · IATT · ATC · all officeld-tagged), grant date, expiration date, renewal-window-opens date, and last sustaining-evidence date. At least one tile is in "Renewal · open" state — meaning the renewal window has opened and Auctor has automatically generated a POA&M item ("Refresh ConMon evidence for re-auth") so the team isn't scrambling six months later.

Click: sidebar **Integrations** → scroll to "Closed-loop demo" panel at the bottom.

Screenshot:



What it shows: scenario trigger buttons covering Tenable CVE feeds (Splunk anomaly path is consolidated into the same closed-loop synthesis · same code path). Click any CVE button. Within 1 second:

- + A live red event scrolls in on the ticker
- + A toast notification confirms the auto-synthesis: **"CVE-2026-1234 → P-AUTO-2026-XXXXXX auto-synthesized · severity critical · controls SC-13 · SI-2 · SLA due in 14 days"**
- + A green attribution chip appears with a clickable link to `/governance` showing the spawned POA&M

Click the green chip link → land on `/governance` with the auto-spawned `P-AUTO-2026-*` rendered in the POA&M backlog. **The spawned POA&M persists across navigation** (v3.0.1 sessionStorage fix).

Why it matters: this is the closed-loop continuous-authorization proof point. ConMon platforms ingest Tenable data. Auctor ingests, correlates, synthesizes, and binds it to the authorization package — closing the loop in real time.

Persona switcher · what each role sees (1.5 min)

Click: top-right persona switcher → choose "Security Control Assessor".

Load: auto-redirect to `/governance/audits` with the SCA persona active.

What it shows: the SCA's default landing page is the audits list. The sidebar drops "Analyze Diagram" (the SCA persona is read-only on diagram upload). The "Sign + lock SAR" button on each finding is enabled — it was disabled when viewed as System Owner.

Optional follow-up: switch to GRC Chief → lands on `/rmf` with the same sidebar (no Analyze Diagram). Switch back to System Owner for cleanup.

Why it matters: federal cyber teams have role-segregated authority. Auctor's Role-Based Access Control (RBAC) model maps to the actual roles — System Owner, Compliance Analyst, CISO, C3PAO Auditor, GRC Chief, Security Control Assessor. Each role lands on the surface that role's day starts on. Each role sees only the actions its authority permits.

A note on persona labels. The two new v3.0 personas (GRC Chief and Security Control Assessor) display as `[Generic] · GRC Chief` and `[Generic] · Security Control Assessor` in the persona switcher. This is intentional for the POC — the placeholder labels let any GRC Chief or SCA on the call inhabit the role without a name conflict. Production deployments use real org-chart names sourced from the customer's identity provider (Microsoft Entra ID / Okta).

§4 · Q&A — anticipated questions

The body of the Q&A runs 6-8 minutes. Below is the recommended division of labor for the most common questions.

QUESTION	LEAD ANSWERS	SPECIALIST BACKSTOPS
Where does the SCA's signature actually go?	Lead presenter (UI shows the flow)	Technical specialist (cryptographic signing roadmap)
What's the FedRAMP authorization status?	Technical specialist (in-house deploy is air-gapped; hosted offering FedRAMP is on the v4.x roadmap)	Architect if scoping question
How does this integrate with our existing CMDB?	Technical specialist (sit-on-top architecture; doesn't replace ServiceNow CMDB)	Lead presenter
What's the pricing model?	Partner + architect (depends on portfolio shape; framework licensing)	—
Can we do a 90-day pilot?	Partner (yes; scope discussion)	Architect
Where's the source code stored?	Technical specialist + architect (private repo; transfer at deployment)	—
What about [competitor X]?	Technical specialist (head-to-head framing · "system of record vs system of action" framing · ServiceNow CCM tracks tickets, Auctor tracks liability)	Lead presenter
How accurate is the AI vision analysis?	Lead presenter (vision model + per-component confidence)	Technical specialist (where it has known gaps)
What's the latency on a real eMASS submission?	Technical specialist (network · PKI handshake · DoD-side ack times)	—
How is the rubric	Lead presenter: the threshold is one component of the rubric. The threshold sets the color band	Technical specialist

different from RAG thresholds?	(red/amber/green) on a single coverage value. The rubric is the full scoring framework: 5 weighted criteria (control coverage · artifact submission · POA&M closure · audit remediation · ConMon attestation) → weighted aggregate score → that score gets compared against the ATO-ready threshold. So the threshold tunes WHEN the rubric flips ATO-ready, but the rubric is doing the work of computing the aggregate. Misbah described both: "build some thresholds" + "you have to be at 80% to be ATO" — the rubric is the gate, the threshold is the cutoff.	(computation transparency · pure-function output · per-office override semantics)
---------------------------------------	---	---

What happens to a project whose ATO is in renewal-window-open?	Lead presenter (federal-realistic: an ATO in renewal-window-open is operationally still granted — the team is just refreshing ConMon evidence for re-auth · the rubric correctly treats this as <code>ato-granted</code> , not <code>draft</code>)	Technical specialist (the underlying ATO state machine + auto-spawn POA&M for renewal evidence)
---	---	---

Explicit conversion question — at the start of Q&A, the lead presenter asks: **"What would your team need to evaluate Auctor.GRC against the alternative tooling in a 30-day pilot?"** This converts a demo into a pilot-scoping conversation.

§5 · Verifying what's real vs. fictional

For an evaluator who wants to verify any claim made during the demo:

Real (verify against issuing authority):

- + NIST 800-53 Rev 5 controls — `https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final`
- + NIST 800-37 Rev 2 RMF — `https://csrc.nist.gov/publications/detail/sp/800-37/rev-2/final`
- + NIST 800-137 ConMon — `https://csrc.nist.gov/publications/detail/sp/800-137/final`
- + NIST 800-53A Assessment Procedures — `https://csrc.nist.gov/publications/detail/sp/800-53a/rev-5/final`
- + FIPS 199 — `https://csrc.nist.gov/publications/detail/fips/199/final`
- + CMMC 2.0 — `https://dodcio.defense.gov/CMMC/`

- + DoD Cloud Computing SRG — <https://dl.dod.cyber.mil/wp-content/uploads/cloud/SRG/>
- + DoD Zero Trust Strategy — <https://dodcio.defense.gov/Library/>
- + NDAA Section 1512 / 1513 — <https://www.congress.gov/>
- + eMASS — <https://emass.apps.mil/>
- + DCMA DIBCAC — <https://www.dcmamil/DIBCAC/>
- + SPRS — <https://www.sprs.csd.disa.mil/>
- + FedRAMP Marketplace — <https://marketplace.fedramp.gov/> (live in app via `?live=on`)
- + NVD CVE feed — <https://nvd.nist.gov/vuln/search> (live in app via `?live=on`)
- + Federal Register notices — <https://www.federalregister.gov/agencies/departments-of-defense> (live in app via `?live=on`)

Live federal data plumbed through the app (toggle via `?live=on`):

- + **NIST OSCAL controls catalog** — fetched from canonical NIST OSCAL endpoint, refreshed daily
- + **NVD CVE feed** — most recent critical/high vulnerabilities
- + **Congress.gov NDAA full-text** — Sections 1512 + 1513 via server-side proxy (browser never sees the data.gov key)
- + **Federal Register cyber notices** — most recent rule notices
- + **FedRAMP Marketplace** — currently-authorized cloud service offerings

Each live data point in the UI carries a `<LiveAttribution>` chip naming its source — the POC never claims provenance it cannot demonstrate. Any SCA can verify the source URL, the count, and the publication date inline.

Fictional or randomized (for demo safety):

- + All persona names (Sarah Patel, Raj Lee, Marcus Hayes, Dana Brooks, etc.) and the two new v3.0 personas (GRC Chief, Security Control Assessor — generic placeholders)
- + All contractor entity names (Aerostar Defense LLC, Mariner Maritime Systems, Polaris Rotorcraft, etc.)
- + All CVE identifiers in the trigger panel (CVE-2026-1234, CVE-2026-1543, etc.)
- + All ATO record IDs (ato-aerostar-api, ato-mariner-fleet, etc.)
- + All POA&M IDs (P-2026-117, P-AUTO-2026-833713, etc.)
- + All audit run IDs (AUDIT-2026-156, AS-2026-141, etc.)
- + All evidence package IDs (AUCTOR-EVIDENCE-2026-Q1-A, etc.)

§6 · Recovery posture · if something breaks live

IF...	THEN...
A page returns 500 or doesn't load	Refresh once. If still broken, switch to the screenshot deck and continue narrating. The architect can re-bind the Vercel alias from standby.
The Tenable trigger doesn't visibly spawn the POA&M	Read the toast notification aloud. Click the green chip link — the spawned POA&M is on /governance. Don't apologize for animation glitches.
Persona switcher doesn't load the new persona's default page	Refresh the destination page once. The session cookie carries through.
ConMon AI tuning panel shows zero recommendations	Stay on the Calendar view. Recommendations are gated by a drift-history threshold; the calendar itself is the wow.
eMASS submit flow stalls mid-stage	Reload <code>/integrations/emass/queue</code> . The previously-submitted package is already in the queue advancing through statuses.
The audience invokes a feature you don't recognize	"Let me have my technical specialist take that one." Never make up an answer.

The rule: if something is wrong, **say so honestly**, pivot to the next surface, recover. Federal cyber audiences respect technical credibility. They will not respect a presenter who oversells a broken flow.

§7 · Pre-call rehearsal · 30-minute countdown

T-30 min — Architect runs `vercel ls + vercel alias ls | grep auctorgrc.vercel.app`. Confirm the latest deploy is **Ready** and aliased.

T-20 min — Lead presenter opens `https://auctorgrc.vercel.app/dashboard` in a fresh browser window. The version pill should read `POC · v3.0.9`. Hard-reload (`Cmd+Shift+R` on macOS or `Ctrl+Shift+R` on Windows/Linux) to clear cached state.

T-15 min — Open all 13 deep-link tabs in order from §8 below. Each should serve `200 OK` in under 2 seconds. If any returns `500`, ping the architect immediately.

T-10 min — Open the persona switcher. Cycle through System Owner → GRC Chief → SCA → System Owner. Each persona's default route should resolve cleanly with the correct sidebar.

T-8 min — Open DevTools console at `https://auctorgrc.vercel.app/dashboard` and run `sessionStorage.clear(); location.reload();`. This wipes any prior rehearsal triage state so the Step 2 simulator fires from a clean queue. Skip this step and you'll see leftover rehearsal events stacked on top of the 12 fresh ones during the live fire — the SCA will notice the count mismatch.

T-7 min — Open `/settings`, click "Simulate NIST 800-53 Rev 5.3 publication". Confirm 12 triage events fire, the bell pulses red with combined badge "19 unread · 1 triage critical", and the sidebar Triage entry shows the red pulse-ring badge. Then click the bell → click `Triage queue · 12` → land on `/governance/triage` with the queue populated. This rehearsal makes the autonomy mic-drop in Step 3 land cleanly without simulator-state confusion. **Then run `sessionStorage.clear(); location.reload();` one final time before the call so the live demo fires from zero state — Step 3 is the autonomy mic-drop, and a leftover queue from rehearsal would dilute it.**

T-5 min — Trigger one Tenable scenario on `/integrations`. Confirm the POA&M auto-spawns within 1 second. Click the green chip link. Confirm `/governance` shows the spawned `P-AUT0-2026-*` (this verifies the v3.0.1 sessionStorage persistence fix).

T-2 min — Re-load `/dashboard`. Verify the pill reads `v3.0.9`. Settle in.

Call start (T-0) — Partner opens. Lead presenter drives. Technical specialist observes. Architect on standby.



§8 · Cheat sheet · pre-load these tabs in demo order

STEP	DEEP LINK
1	https://auctorgrc.vercel.app/dashboard
2	https://auctorgrc.vercel.app/dashboard/office/disa → /dashboard/office/disa/sub/disa-jsp-peo → /dashboard/office/disa/project/disa-cloud-mod
3	https://auctorgrc.vercel.app/settings (simulator) → https://auctorgrc.vercel.app/governance/triage → https://auctorgrc.vercel.app/governance/triage/audit
4	https://auctorgrc.vercel.app/rmf
5	https://auctorgrc.vercel.app/compliance-posture/categorize
6	https://auctorgrc.vercel.app/upload
7	https://auctorgrc.vercel.app/governance/audits
8	(drill into a finding from step 7)
9	https://auctorgrc.vercel.app/integrations/emass/studio
10	https://auctorgrc.vercel.app/integrations/emass/queue
11	https://auctorgrc.vercel.app/policy-library then /policy-library/marketplace
12	https://auctorgrc.vercel.app/compliance-posture/common
13	https://auctorgrc.vercel.app/compliance-posture then /integrations
Persona switch	https://auctorgrc.vercel.app/?persona=sca then ?persona=grc-chief then ?persona=system-owner

Use ⌘K (macOS) / Ctrl+K (Windows/Linux) command palette for quick navigation if a URL isn't pre-loaded — it covers every route in the application.

Drill deep-links (v3.0.3+ surfaces · click-required)

The deep drill-down surfaces shipped in v3.0.3 → v3.0.8 are reachable by clicking the parent route — they don't have direct URLs. Pattern: open the parent, then click the named element. Right-side drill sheets render between 384–896 px depending on the surface (the **triage event drill** is the widest at 768 px after the v3.0.7.3 width unlock; SAR finding sheets render at 672 px; ATO tile drills at 768 px; etc.).

DRILL	PARENT ROUTE	CLICK TARGET
Triage event drill (4-stage · Snapshot · Diff · Impact · AI-suggest)	/governance/triage	any of the 12 triage events in the queue (now 768 px wide after v3.0.7.3 width unlock)
Audit stage timeline drill	/governance/audits/AUDIT-2026-156	any stage in the 6-stage timeline ol
ATO tile drill (3-tab · Renewal · Controls Delta · Inheritance)	/compliance-posture	any of the 8 ATO tiles
Heatmap cell drill (4-tab · Overview · Evidence · Remediation · History)	/governance	any of the 64 heatmap cells
FedRAMP milestone drill (3-tab · Status · Required Controls · Evidence)	/compliance-posture	any of the 5 FedRAMP roadmap milestones
ConMon AI rationale "Why?" drill (3-tab · Why · Confidence · Impact)	/compliance-posture/common	"Why?" button next to any AI tuning recommendation
eMASS queue row drill (2-tab · Summary · Validation)	/integrations/emass/queue	any submission row
Connector drill (2-tab · Health · Recent Events)	/integrations	any of the 6 connector tiles
Location drill (3-tab · Overview · Systems · Incidents)	/governance/locations	any location row

If Vincent or the SCA asks "what's behind that?" — click the surface to open the drill. Every drill carries inverse-link summary chips ("Referenced by N findings · M evidence files · K POA&Ms") at the top so the audience sees both downstream and upstream relationships.

§9 · Glossary + Sources

Definitions verified against issuing-authority publications. Sources at the end.

Advana — The Department of Defense's enterprise data analytics platform.

AO (Authorizing Official) — The senior federal official with authority to assume responsibility for operating an information system at an acceptable level of risk. Per NIST SP 800-37 Rev 2 §2.4.

API (Application Programming Interface) — A set of definitions allowing software systems to communicate.

ATC (Authority to Connect) — A specific eMASS authorization type for systems connecting to a higher-level authorized network.

ATO (Authorization to Operate) — The official management decision granting authority to operate an information system. Per RMF Step 5 (NIST SP 800-37 Rev 2).

CA-2 — A NIST 800-53 control: Control Assessments. The formal independent assessment of controls.

CA-7 — A NIST 800-53 control: Continuous Monitoring. The framework for ongoing assessment of security control effectiveness.

CAM (Continuous Authorization and Monitoring) — A category of products and processes that automate ongoing security control assessment.

CIO (Chief Information Officer) — Senior executive responsible for information technology.

CISO (Chief Information Security Officer) — Senior executive responsible for information security.

CMDB (Configuration Management Database) — A repository tracking IT configuration items and their relationships.

CMMC (Cybersecurity Maturity Model Certification) — DoD certification framework for defense contractors. CMMC 2.0 has three levels: Foundational, Advanced, Expert.

ConMon (Continuous Monitoring) — Ongoing assessment of security controls per NIST SP 800-137.

C3PAO (Certified Third Party Assessment Organization) — An organization authorized to conduct CMMC Level 2 certification assessments.

CUI (Controlled Unclassified Information) — Information requiring safeguarding but not classified. Defined in 32 CFR 2002.

CVE (Common Vulnerabilities and Exposures) — A registry of publicly disclosed cybersecurity vulnerabilities, each with a unique identifier. Maintained by MITRE.

CVSS (Common Vulnerability Scoring System) — A framework for rating CVE severity. Maintained by FIRST.org.

DCMA (Defense Contract Management Agency) — DoD agency that manages defense contracts. Hosts DIBCAC.

DIB (Defense Industrial Base) — The defense-related industrial complex serving the U.S. military.

DIBCAC (Defense Industrial Base Cybersecurity Assessment Center) — DCMA component that conducts cybersecurity assessments for DIB contractors.

DoD (Department of Defense) — The U.S. Department of Defense.

DoD Cloud Computing SRG (Security Requirements Guide) — DoD-specific cloud security requirements defining Impact Levels IL2 through IL6.

DoD ZT (Zero Trust) — DoD Zero Trust Strategy, currently version 2.0.

eMASS (Enterprise Mission Assurance Support Service) — DoD's official system of record for RMF authorization packages.

FedRAMP (Federal Risk and Authorization Management Program) — Government-wide cloud security authorization program.

FIPS 140-3 — Federal standard for cryptographic module validation.

FIPS 199 — Federal Information Processing Standard for categorizing information systems by Confidentiality / Integrity / Availability impact.

GRC (Governance, Risk, and Compliance) — The umbrella discipline integrating governance, risk management, and compliance.

IATT (Interim Authority to Test) — A temporary authorization permitting testing before full ATO grant.

IL2 / IL4 / IL5 / IL6 — DoD Cloud Computing SRG Impact Levels. IL2 = public-facing data; IL4 = CUI / non-mission-critical; IL5 = mission-critical / CUI; IL6 = classified up to SECRET.

LLM (Large Language Model) — A neural network trained on text data, capable of generating and reasoning about language.

MFA (Multi-Factor Authentication) — Authentication using two or more independent credentials.

mTLS (mutual Transport Layer Security) — TLS where both client and server authenticate each other.

NDAA (National Defense Authorization Act) — Annual U.S. federal law specifying defense budget and policy. Section 1512 mandates AI cybersecurity policy; Section 1513 mandates enforcement.

NIST (National Institute of Standards and Technology) — U.S. federal agency that develops cybersecurity standards.

NIST 800-37 Rev 2 (Risk Management Framework) — The six-step RMF: Categorize, Select, Implement, Assess, Authorize, Monitor.

NIST 800-53 Rev 5 — The catalog of security and privacy controls for federal information systems.

NIST 800-53A — Assessment procedures for the controls in NIST 800-53.

NIST 800-137 — Information Security Continuous Monitoring framework.

NIST 800-171 — Protecting Controlled Unclassified Information in nonfederal systems.

NIST AI RMF — NIST AI Risk Management Framework (2023).

NIST SP 800-18 Rev 1 — Guide for developing System Security Plans.

P-ATO (Provisional Authority to Operate) — A FedRAMP authorization type granted by the Joint Authorization Board.

PKI (Public Key Infrastructure) — Framework for issuing and managing digital certificates.

POA&M (Plan of Action & Milestones) — Document tracking open security gaps, owners, and target completion dates.

POC (Proof of Concept) — A demonstration system intended to validate feasibility before production.

Rubric (project rubric · v3.0.10) — the scoring framework that computes a project's "X% ATO-ready" headline number from 5 weighted criteria: control coverage (30%) · artifact submission (25%) · POA&M closure (25%) · audit remediation (15%) · ConMon attestation (5%). Aggregate clamped to [0, 100]. The rubric is gated by the **ATO-ready threshold** below.

ATO-ready threshold (v3.0.10) — the percentage at which the rubric score flips a project from `in-review` to `ato-ready` closure stage. Default 80% (Misbah's CFPB-pattern). Configurable globally and per-office via the `Thresholds` popover. Each office can dial its own (CFPB might prefer 80% while ARCYBER is happier at 70%).

Closure stage (v3.0.10) — one of 5 lifecycle phases for a project, computed deterministically from the rubric: `draft` (score < 50%) · `in-review` (50% ≤ score < threshold) · `ato-ready` (score ≥ threshold AND no critical blocking POA&Ms) · `ato-granted` (linked ATO is `active` or `renewal-window-open`) · `closed` (ATO active AND all POA&Ms done AND no open audit findings).

Renewal-window-open — an ATO state where the original authorization is still operationally valid but the team has entered the renewal cycle (typically the 6-month window before expiry). The rubric treats `renewal-window-open` as `ato-granted` for closure-stage purposes — the team is refreshing ConMon evidence for re-auth, not in `draft` again.

RMF (Risk Management Framework) — NIST's six-step process for managing security and privacy risk in federal information systems.

SaaS (Software as a Service) — Software delivered as a hosted service.

SAR (Security Assessment Report) — Document recording an independent assessor's evaluation of security control effectiveness.

SBOM (Software Bill of Materials) — A formal inventory of software components and dependencies. Required for federal AI deployments under NDAA Section 1513.

SCA (Security Control Assessor) — Independent assessor of security control effectiveness. Per NIST SP 800-37 Rev 2 §2.4.

SecOps (Security Operations) — Discipline and tooling for ongoing security monitoring, incident detection, and response.

SIEM (Security Information and Event Management) — Software aggregating and analyzing security event data.

SLA (Service-Level Agreement) — Commitment to a specific level of service or response time.

SPRS (Supplier Performance Risk System) — DoD's risk-scoring system for defense contractors. 110-point cyber compliance score derived from NIST 800-171 self-assessment.

SRG (Security Requirements Guide) — DoD-specific security requirements documents.

SSO (Single Sign-On) — Authentication mechanism allowing one credential to access multiple systems.

SSP (System Security Plan) — Document describing how an information system implements its applicable security controls. Per NIST SP 800-18 Rev 1.

TDE (Transparent Data Encryption) — Database-level encryption that operates without application code changes.

VPN (Virtual Private Network) — A secure network connection over a public network.

ZT (Zero Trust) — Security architecture assuming no implicit trust based on network location.

Sources

- + **NIST CSRC publications** — <https://csrc.nist.gov/publications>
 - + **DoD CIO library** — <https://dodcio.defense.gov/Library/>
 - + **eMASS** — <https://emass.apps.mil/>
 - + **Congress.gov** — <https://www.congress.gov/>
 - + **CMMC AB** — <https://cyberab.org/>
 - + **FedRAMP Marketplace** — <https://marketplace.fedramp.gov/>
 - + **MITRE CVE** — <https://cve.mitre.org/>
 - + **FIRST CVSS** — <https://www.first.org/cvss/>
 - + **DCMA DIBCAC** — <https://www.dcmamil/DIBCAC/>
 - + **SPRS** — <https://www.sprs.csd.disa.mil/>
-

End · Auctor.GRC v3.0.10 · Demo Guide · 2026-05-01 · **From assertion to authority.**